

CPPG · 개인정보관리사

오답노트 상세해설 · 보강본

39문항 원문 보존 · 단계별 풀이 · 선지별 O/X · 현행 기준 교차검증

핵심 원칙

지문과 선지는 바꾸지 않고, 잘못된 문항은 억지로 정당화하지 않습니다.
정답불성립 · 복수오답 · 시행일 함정을 해설에서 명확히 표시했습니다.

기준일 2026. 8. 15 | 예랑이랑 통합본 93p 대조

이 책의 편집 원칙

- 문제 지문과 선지는 첫 번째 PDF에서 추출한 문구를 그대로 두고, 줄바꿈만 읽기 좋게 복원했습니다.
- 정답만 외우지 않도록 '쟁점 찾기 → 규칙 확인 → 지문 적용 → 정답 확정' 순서로 풀이했습니다.
- 정답 선지는 왜 맞는지, 나머지 선지는 어느 단어·조건·기산점 때문에 틀리는지 각각 설명했습니다.
- 예랑이랑 통합본은 관련 페이지를 연결하고, 빠진 주제는 현행 법령·공식 안내서로 보강했습니다.
- 법령·고시·인증기준은 기준일 이후 바뀔 수 있으므로 실제 시험 공고가 정한 출제 기준일을 최우선으로 합니다.

중요: 이 문서는 학습용 해설입니다. 법률 자문이나 실제 컴플라이언스 결정은 최신 원문 법령과 관할기관의 공식 해석을 다시 확인하세요.

표시 읽는 법

정상	원 정답과 현행 근거가 자연스럽게 일치
문항 주의	문구가 넓거나 전제가 부족해 조건부 해석 필요
문항 오류 / 복수오답	원 정답표를 그대로 외우면 안 됨. 해설의 정정 결론 우선
시행일 주의	같은 문장도 시험 기준일에 따라 O/X가 달라짐

먼저 고칠 문항

원 문서의 해설보다 아래 정정표를 우선해 학습하세요.

문항	정정	정정 내용
Q3	가명정보	④는 요건 충족 시 가능할 수 있음. '유상 제공=금지' 아님
Q8	사고 순서	법은 단일 직렬 순서를 규정하지 않음. 차단·통지·신고 병행
Q25	국외이전	⑤ 외에 ②도 공개/통지 조건이 빠져 불안전
Q32	국외이전 신고	일반 신고 의무 없음. ㉠·㉡만 옳지만 답지 없음
Q40	RAG·국외이전	③뿐 아니라 ②의 '국외 이전 신고서'도 부정확
Q43	가명·익명	④ 외에 ⑤도 보편적 법정 의무로 단정하기 어려움
Q50	최소 이전	배치 전송은 총량을 줄이지 않지만 언제나 위법한 것은 아님
Q83	접속기록	2026.8.15 기준 ②와 ③ 모두 맞을 수 있음
Q88	예비인증	본인증은 예비취득+1년이 아니라 신고수리+6개월
Q94	Global CBPR	50개는 2027.3.31까지, 이후 57개

시행일 타임라인

2026.09.11	개인정보 보호법 유출 가능성 통지 등 일부 개정 시행
2026.10.31	접속기록 점검주기 자율화·접속기록 대상 확대 등 고시 일부 시행
2027.01.01	2026.7.1 고시 중 일부 공공시스템 조항 시행
2027.04.01	Global CBPR 신규·갱신 인증 57개 프로그램 요구사항 적용

목차

이 책의 편집 원칙	2
표시 읽는 법	2
먼저 고칠 문항	3
시행일 타임라인	3
목차	4
1과목 · 개인정보보호의 이해	7
Q3. 헬스케어 A기업 → 제약사 B 데이터 판매	8
Q8. 침해사고 조치 순서	10
Q9. 도로 교통 CCTV + AI 영상분석	12
Q13. OECD 8원칙 ↔ 개보법 대응	14
Q19. CSAP 클라우드 보안인증 서비스 유형	15
Q20. 최소 수집 원칙 위반 아닌 것	17
2과목 · 개인정보 보호 제도	19
Q24. 국외 이전 설명	20
Q25. 국외 이전 조건	22
Q26. 개인정보 처리방침 공개 의무	24
Q27. 정보주체 권리 보장 조항 매칭	26
Q28. 만 14세 미만 아동 개인정보	28
Q30. 전문 CPO 지정 대상	30
3과목 · 개인정보 라이프사이클 관리	31
Q31. 필수 수집 불가 항목 고르기	32

Q32. 제3자 제공 vs 위수탁	34
Q34. 영리 목적 광고성 정보	36
Q40. CloudStream RAG 학습	38
Q43. 파기·가명정보·익명정보	40
Q47. MarketQ 위탁 관리·감독	42
Q50. 스마트카 국경 간 최소 이전	44

4과목 · 개인정보 보호조치 46

Q56. 내부 관리계획	47
Q57. 웹 공격 유형 ↔ 방어 기법	49
Q58. 일방향 암호화(해시) 대상	51
Q59. MedPark 랜섬웨어 재발방지	53
Q61. VPN + 내부망 다중 접근통제	55
Q62. VPN 설명	57
Q65. 물리적 보호조치 및 CCTV	58

5과목 · 개인정보 관리체계 59

Q82. 공공시스템운영기관 안전조치	60
Q83. 접속기록 보관 기준	62
Q86. ISMS-P 추진체계	64
Q87. ISMS-P 기대효과	66
Q88. 가상자산사업자 ISMS-P 예비인증	68
Q89. 중소기업 ISMS-P 인증 특례	70
Q90. ISMS-P 사후관리 및 보완조치	72
Q93. ISMS-P 인증범위	74

Q94. Global CBPR	76
Q95. ISO/IEC 27001:2022	78
Q96. 개인정보 영향평가(PIA)	79
Q97. 위치정보법 총론	81
Q98. 위치정보법 제18조 이용약관 명시사항	83

공식 근거 · 추가 확인 링크 85

자료 사용 메모	85
--------------------	----

1과목 · 개인정보보호의 이해

개념·원칙·유출·기초 보안

수록 문항: Q3, Q8, Q9, Q13, Q19, Q20

문항 번호 순으로 배열했습니다. 원문 안의 과목 표기는 보존했으며, 이 장의 분류는 전체 시험 번호 구간을 기준으로 정리했습니다.

Q3. 헬스케어 A기업 → 제약사 B 데이터 판매

문항 주의

정답 결론: ③ (출제 의도상 최선)

문제 원문 · 선지

Q3. 다음의 제휴와 관련하여 A기업이 우선적으로 준수해야 할 최소한의 조치로 가장 적절한 것은?

보기

국내 헬스케어 스타트업 A기업은 웨어러블 기기를 통해 이용자의 심박·수면·위치 데이터를 실시간 수집한다. 회사는 건강 콘텐츠 개인화를 이유로 이용약관에 포괄 동의를 받은 상태다. 최근 A기업은 해당 데이터를 제약사 B기업에 판매해 신약 연구에 활용하도록 제휴계약을 체결했다.

- ① 기존 약관 동의만으로 충분하므로 추가 동의·고지는 불필요하다
- ② 데이터 상품화는 부가적 수익 활동이므로 정당한 이익으로 처리할 수 있다
- ③ 정보주체 개별 동의 획득, 목적 변경 고지, 제3자 제공에 대한 기록 관리가 필요하다
- ④ 가명처리 후 제공하면 제약사가 추가 동의 없이 이용할 수 있다
- ⑤ 연구 목적이므로 별도의 동의 없이 활용 가능하다.

문항 주의

③은 가장 안전한 준수 경로이지만, ④도 과학적 연구 목적과 가명정보 요건을 모두 갖추면 가능할 수 있다. '가명처리하면 무조건 가능'도, '대가를 받으면 무조건 금지'도 정확하지 않다.

STEP BY STEP

- 1 심박·수면은 건강정보로서 민감정보이고, 위치 데이터에는 위치정보법 검토도 추가된다.
- 2 건강 콘텐츠 개인화에서 제약사 판매·연구로 목적과 수령자가 바뀌었으므로 기존 포괄 동의만으로 처리할 수 없다.
- 3 가장 보수적인 경로는 민감정보 처리, 목적 외 이용·제공, 제3자 제공에 필요한 사항을 분리해 알리고 적법한 동의를 받는 것이다.
- 4 대안으로 가명정보 특례를 쓰려면 과학적 연구 목적, 가명처리 적정성, 추가정보 분리, 재식별 금지, 제공 범위 통제가 모두 필요하다.

선지별 판정

선지	판정	해설 / 해설하는가
①	오답	포괄 동의는 서로 다른 처리 목적과 민감정보·제3자 제공 동의를 한꺼번에 대신하지 못한다.
②	오답	정당한 이익은 법 제15조의 수집·이용 근거 중 하나이며, 판매 목적 제3자 제공을 자동 정당화하지 않는다.
③	정답	새 목적과 제3자 제공을 명확히 알리고 필요한 동의를 구분해 받으며 제공 내역을 관리하는 가장 안전한 조치다.
④	조건부	과학적 연구용 가명정보 제공은 동의 없이 가능할 수 있지만, 가명처리 한 번만으로 제약사의 모든 추가 이용이 허용되는 것은 아니다.
⑤	오답	연구라는 명칭만으로 원본 개인정보를 동의 없이 쓸 수 없다. 가명정보 특례 또는 별도의 적법한 처리 근거가 필요하다.

예랑이랑 통합본 연결

p.08, p.21, p.47-48, p.61, p.66-67

추가 보강

- 2026.3 가명정보 처리 가이드라인은 AI 학습 등 과학적 연구 활용을 위험도 기반으로 판단한다.
- 상업적·산업적 연구도 과학적 방법을 적용하면 과학적 연구에 포함될 수 있다.

근거 키워드

개인정보 보호법 제17조, 제18조, 제23조, 제28조의2-제28조의5 · 위치정보법 제18조, 제19조

시험장에서: 포괄 동의 + 민감정보 + 목적 변경 + 제3자 제공이 함께 나오면 각각의 법적 근거를 따로 확인한다.

Q8. 침해사고 조치 순서

순서형 주의

정답 결론: ④ (출제 의도상)

문제 원문 · 선지

Q8. 다음 지문은 개인정보 침해 사고 발생 시 수행해야 할 조치들을 나열한 것이다. 조치 순서로 가장 적절한 것을 고르시오.

보기

- a. 사고 사실 확인 및 피해 범위 파악
- b. 개인정보보호책임자 및 최고경영진 보고
- c. 관계 기관(개인정보보호위원회 등)에 신고·통보
- d. 정보주체에 사고 사실 및 대응 계획 고지
- e. 재발 방지 대책 수립 및 시스템 보완

- ① $a \rightarrow b \rightarrow c \rightarrow d \rightarrow e$
- ② $a \rightarrow d \rightarrow b \rightarrow c \rightarrow e$
- ③ $b \rightarrow a \rightarrow c \rightarrow d \rightarrow e$
- ④ $a \rightarrow b \rightarrow d \rightarrow c \rightarrow e$
- ⑤ $b \rightarrow a \rightarrow d \rightarrow c \rightarrow e$

순서형 주의

법은 a-b-d-c-e라는 단일 직렬 순서를 규정하지 않는다. 통지는 '지체 없이', 일정한 신고는 '72시간 이내'이므로 ④가 가장 자연스럽지만, 실제 대응에서는 차단·증거보전·통지·신고가 병행된다.

STEP BY STEP

- 1 먼저 사고 사실과 범위를 확인해야 통지·신고 내용을 만들 수 있다.
- 2 내부 보고로 의사결정과 자원을 확보한다. 다만 이 단계와 동시에 계정 잠금, 서버 격리, 증거보전을 수행해야 한다.
- 3 정보주체 통지는 지체 없이 해야 하고, 신고 요건에 해당하면 보호위원회 또는 KISA에 72시간 이내 신고한다.
- 4 마지막에 원인 분석과 재발방지 조치를 내부 관리계획에 반영한다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	차선	신고를 통지보다 먼저 고정한다. 법정 기한만 보면 통지가 더 긴급하므로 출제 의도와 어긋난다.
②	오답	내부 보고보다 외부 고지를 앞세워 대응 책임자와 의사결정 구조를 건너뛴다.
③	오답	사실 확인 전에 내부 보고가 먼저이며, 신고를 통지보다 고정적으로 앞세운다.
④	정답	사실 확인-내부 보고-지체 없는 통지-72시간 신고-재발방지의 기한 논리에 가장 가깝다.
⑤	오답	사실 확인보다 보고가 먼저여서 보고 내용과 피해 범위를 확정하기 어렵다.

예랑이랑 통합본 연결

p.11, p.50, p.65, p.92

추가 보강

- 2026.9.11 시행 예정 개정에는 실제 유출이 확인되지 않아도 유출 가능성을 알게 된 경우의 통지가 추가된다.
- b는 '경영진 보고'이지 '긴급 차단'이 아니다. 원 문서가 둘을 혼동한 부분을 바로잡았다.

근거 키워드

개인정보 보호법 제34조 · 개인정보 보호법 시행령 제39조-제40조

시험장에서: 통지=정보주체·지체 없이, 신고=기관·요건 충족 시 72시간 이내로 분리해 외운다.

Q9. 도로 교통 CCTV + AI 영상분석

정상

정답 결론: ④

문제 원문 · 선지

Q9. 다음 중 A기업이 즉시 이행해야 할 개선 조치로 가장 적절하지 않은 것은?

보기

2025년 5월, AI 스타트업 A기업은 서울 시내 1,500대의 도로 교통 CCTV 영상을 수집하여 실시간 교통량을 분석하는 AI 모델을 개발하였다. 분석된 교통량 정보는 공공 API를 통해 실시간으로 기관과 민간에 제공되고 있다. A기업은 개인정보 침해 우려를 줄이기 위해 차량 번호판에는 블러 처리를 적용했지만, 영상 내 행인의 얼굴은 식별 가능한 상태로 노출되어 있다. A기업은 서울시와의 협약 하에 영상 수집권을 부여받았으며, 원본 영상은 사내 연구용으로 일부 저장하고 있다.

- ① 차량 번호판과 동일하게 행인 얼굴도 식별 불가능한 수준으로 모자이크 처리한다
- ② CCTV 설치 장소에 영상 AI 분석 목적 및 개인정보 비식별 조치를 명시한 안내 표지판을 추가 설치한다
- ③ API 응답에 개인이 식별될 수 있는 영상 프레임이 포함되지 않도록 출력 전 단계에서 비식별 조치를 강화한다
- ④ AI 모델 성능 개선을 위해 원본 영상을 장기 보관하고 정기 백업 체계를 마련한다
- ⑤ 서울시와의 업무 협약서에 영상정보의 수집목적, 보관기간, 제3자 제공 제한 등을 명시적으로 규정한다.

STEP BY STEP

- 1 행인 얼굴과 번호판이 식별 가능하면 개인정보이므로 출력·공개 단계에서 식별 위험을 줄여야 한다.
- 2 수집 목적, 보관기간, 제공 범위와 서울시-A기업의 위탁·제공 관계를 문서로 명확히 해야 한다.
- 3 목적 달성 뒤 원본을 지체 없이 파기해야 하므로 성능 개선을 이유로 장기 보관하는 ④가 개선 조치가 아니다.

선지별 판정

선지	판정	해 맞고 / 해 풀리는가
①	맞음	행인 얼굴을 식별 불가능한 수준으로 처리하면 불필요한 식별 위험을 줄인다.
②	맞음	안내판에 설치 목적·촬영 범위·시간·관리책임자 등 법정사항을 알리고 추가 설명을 할 수 있다.
③	맞음	공개 API에서 개인 식별 프레임을 제거하는 것은 제3자 노출 위험을 직접 줄인다.
④	정답	원본 장기 보관과 백업은 목적 제한·보유 최소화·파기 원칙에 반한다.
⑤	맞음	협약에서 목적·기간·재제공 제한·파기·감독 책임을 정하는 것은 적절하다.

예랑이랑 통합본 연결

p.08, p.20, p.47-48, p.65, p.69-70

추가 보강

- AI 학습에 원본 영상을 다시 쓰려면 당초 목적과의 관련성, 가명정보 특례 또는 별도 근거를 다시 검토한다.
- 안내판의 법정 기재사항과 추가 설명은 구분해야 한다.

근거 키워드

개인정보 보호법 제21조, 제25조 · 표준 개인정보 보호지침의 개인영상정보 규정

시험장에서: '개선 조치가 아닌 것'은 위험을 줄이는지 늘리는지부터 본다.

Q13. OECD 8원칙 ↔ 개보법 대응

정상

정답 결론: ④

문제 원문 · 선지

Q13. 다음 중 OECD 8원칙과 개인정보보호법 상의 대응 원칙을 잘못 연결한 것은? (2과목)

- ① 수집제한의 원칙 — 목적에 필요한 최소정보의 수집
- ② 이용제한의 원칙 — 목적 범위 내에서 적법하게 처리 및 목적 외 활용금지
- ③ 정보의 안전한 보호의 원칙 — 권리 침해 가능성 등을 고려하여 안전하게 관리
- ④ 목적 명확화 원칙 — 목적을 명확하게 하여야 하고 그 목적에 필요한 범위에서 최대한의 개인정보를 적법하고 정당하게 수집
- ⑤ 책임의 원칙 — 개인정보처리자의 책임준수, 신뢰 확보 노력

STEP BY STEP

- 1 각 원칙의 핵심어를 분리한다: 수집제한=최소, 목적명확화=수집 시까지 명확, 정보정확성=정확·완전·최신.
- 2 ④의 '최대한'을 확인한다.
- 3 개보법 제3조 제1항은 '최소한의 개인정보만' 수집하도록 하므로 ④가 잘못 연결되었다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	맞음	수집제한은 목적에 필요한 최소한의 수집과 연결된다.
②	맞음	이용제한은 명확한 목적 범위를 넘는 이용·제공을 제한한다.
③	맞음	안전성 확보는 권리 침해 가능성과 위험 정도를 고려한 보호조치다.
④	정답	'최대한'이 아니라 '최소한'이어야 한다.
⑤	맞음	책임의 원칙은 법적 책임·의무를 준수하고 신뢰를 얻기 위한 노력과 연결된다.

예랑이랑 통합본 연결

p.07, p.36-37

추가 보강

- OECD 원칙과 개보법 제3조는 완전한 1:1 대응표가 아니라 취지 대응표다.

근거 키워드

OECD Guidelines on the Protection of Privacy · 개인정보 보호법 제3조

시험장에서: 최대/최소처럼 한 단어만 바꾼 선지를 먼저 표시한다.

Q19. CSAP 클라우드 보안인증 서비스 유형

제도 변경 주의

정답 결론: ⑤ (현행·기존 인증유형 기준)

문제 원문 · 선지

Q19. 다음 중 클라우드 보안 인증제도(CSAP)에서 분류하는 서비스 유형이 아닌 것은?

- ① IaaS
- ② SaaS 표준
- ③ SaaS 간편
- ④ DaaS
- ⑤ PaaS

제도 변경 주의

KISA 현행 안내는 인증유형을 IaaS, SaaS, DaaS로 제시하고 기존 SaaS 표준·간편을 병행한다. PaaS는 독립된 기존 인증유형으로 열거되지 않지만 등급제 확대 과정의 최신 공고를 시험 기준일에 다시 확인해야 한다.

STEP BY STEP

- 1 CSAP의 '서비스 모델'과 '등급'을 분리한다.
- 2 KISA의 기존 인증유형 목록 IaaS, SaaS 표준, SaaS 간편, DaaS를 대조한다.
- 3 목록에 독립 유형으로 없는 PaaS인 ⑤를 고른다.

선지별 판정

선지	판정	해설고 / 해설리는가
①	맞음	IaaS는 인프라형 기존 인증유형이다.
②	맞음	SaaS 표준은 기존 인증유형이다.
③	맞음	SaaS 간편은 축소 통제항목을 적용하는 기존 인증유형이다.
④	맞음	DaaS는 데스크톱 서비스 인증유형이다.
⑤	정답	PaaS는 현행 KISA 기존 유형 목록에서 독립 인증유형으로 열거되지 않는다.

예랑이랑 통합본 연결

직접 수록 없음; p.33의 클라우드 국제표준, p.76의 클라우드 이용 보안과 연결

추가 보강

- CSAP 유형과 상·중·하 등급은 서로 다른 축이다.
- 공식 사이트는 기존 유형의 유효기간을 5년으로 안내한다.

근거 키워드

KISA 클라우드서비스 보안인증제 제도소개 · 클라우드컴퓨팅서비스 보안인증에 관한 고시

시험장에서: 아이-사표-사간-다로 기존 유형을 기억한다.

Q20. 최소 수집 원칙 위반 아닌 것

사실관계 주의

정답 결론: ⑤ (출제 의도상)

문제 원문 · 선지

Q20. 다음 중 개인정보 최소 수집 원칙 위반 사례로 가장 적절하지 않은 것은?

- ① 모바일 메신저 가입 시 친구 추천 기능 개선을 위해 연락처 목록 업로드를 필수로 요구
- ② 아동용 교육 앱 가입 시 보호자 동의 확인 목적 없이 아동의 상세 주소·학교명 수집
- ③ 온라인 서점이 전자책 DRM 관리를 이유로 기기 고유 식별번호(ID)를 자동수집
- ④ 구직 플랫폼이 이력서 작성 편의 기능을 이유로 게시물 열람·친구목록·이메일 주소 등 광범위 권한 묶음을 요구
- ⑤ 국가 기술자격 시험 접수를 위해 성명·주민번호·사진을 필수로 요구

사실관계 주의

③의 기기 식별번호가 DRM에 정말 필요한지, 어떤 법적 근거와 고지를 갖췄는지에 따라 결론이 달라질 수 있다. 다만 ⑤는 국가기술자격 법령에 근거한 본인확인·시험관리 목적의 필수 항목이라는 출제 의도가 명확하다.

STEP BY STEP

- 1 서비스 본질에 꼭 필요한 정보인지 묻는다.
- 2 편의·추천·개선 목적이면 선택 수집으로 돌릴 수 있는지 본다.
- 3 법률에 구체적 근거가 있는 주민번호 처리인지 확인한다.
- 4 국가기술자격 시험의 성명·주민번호·사진은 법적 업무 수행에 필요한 범위이므로 ⑤가 위반 사례가 아니다.

선지별 판정

선지	판정	해설고 / 해설리유
①	위반	친구 추천은 부가 기능이므로 전체 연락처 업로드를 가입 필수로 묶기 어렵다.
②	위반	보호자 확인과 무관한 상세 주소·학교명은 목적 관련성과 최소성이 부족하다.
③	주의	DRM 식별 목적의 필요성이 입증될 수 있으나 자동수집의 고지·근거·대체수단을 추가로 봐야 한다.
④	위반	이력서 편의 기능을 이유로 광범위한 권한을 묶어 필수화하면 최소수집에 반한다.
⑤	정답	법령에 따른 시험 접수·본인확인에 필요한 항목으로 볼 수 있다.

예랑이랑 통합본 연결

p.46, p.59, p.61-62, p.64

추가 보강

- 최소한이라는 점의 입증책임은 개인정보처리자에게 있다.
- 선택정보 거부를 이유로 본질적 서비스 제공을 거부하면 안 된다.

근거 키워드

개인정보 보호법 제16조, 제24조의2 · 정보통신망법 제22조의2

시험장에서: 목적-필수성-법적 근거의 3단계로 판단한다.

2과목 · 개인정보 보호 제도

국외이전 · 권리 · 아동 · CPO

수록 문항: Q24, Q25, Q26, Q27, Q28, Q30

문항 번호 순으로 배열했습니다. 원문 안의 과목 표기는 보존했으며, 이 장의 분류는 전체 시험 번호 구간을 기준으로 정리했습니다.

Q24. 국외 이전 설명

표현 주의

정답 결론: ②

문제 원문 · 선지

Q24. 개인정보 국외 이전에 관한 설명으로 가장 적절하지 않은 것은?

- ① 국외 이전 시에는 이전받는 자, 이전 국가, 이전 목적, 항목, 보유·이용기간, 보호조치 등에 대해 정보주체에게 알리고 동의를 받아야 한다
- ② 계약에 따른 업무처리를 위해 국외 클라우드에 일시 보관만 하는 경우는 국외이전에 해당하지 않는다
- ③ 적정성 인증(또는 이에 상응하는 제도)이 있는 국가로 이전하는 경우에는 별도 동의 없이 가능하다
- ④ 국외 위탁·제공 모두에 대해 이전 경로의 보호조치(암호화, 접근통제, 재제공 통제 등)를 설계해야 한다
- ⑤ 국외 이전 후에도 정보주체 권리행사 창구(국내대리인 등)와 사고 대응·통지 책임의 연속성이 확보되어야 한다.

표현 주의

②는 명백히 틀리지만 ①도 모든 국외이전에 동의가 필수인 것처럼 읽으면 부정확하다. 동의는 여러 허용 근거 중 하나이며, 계약 이행을 위한 위탁·보관 등 법정 예외가 있다.

STEP BY STEP

- 1 국외이전의 범위부터 본다: 제공·조회·처리위탁·보관이 모두 포함된다.
- 2 '일시 보관'도 국외 서버에 저장되는 보관이므로 이전 기간과 관계없이 국외이전이다.
- 3 허용 근거 하나를 갖추고 고지·보호조치·권리보장을 이어가야 한다.
- 4 따라서 보관은 국외이전이 아니라고 단정한 ②가 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	원칙 설명	동의 경로를 택할 때는 법정 고지사항을 알리고 별도 동의를 받아야 한다. 다만 동의만이 유일한 근거는 아니다.
②	정답	법 제28조의8은 보관을 명시적으로 국외이전에 포함한다.
③	취지상 맞음	보호위원회가 실질적 동등 수준을 인정한 국가·기구로의 이전은 별도 동의 없이 가능하다.
④	맞음	전송·저장 과정의 안전조치와 재제공 통제를 계약과 시스템에 반영해야 한다.
⑤	맞음	국외이전 뒤에도 권리행사와 유출 대응이 끊기지 않아야 한다.

예랑이랑 통합본 연결

p.22-23, p.37, p.61, p.66-69

추가 보강

- 캐시·백업·재해복구 복제본도 국외에 저장되면 보관형 국외이전이다.
- 국내대리인은 모든 국외이전에 자동 필요한 것이 아니라 법정 지정대상 여부를 별도로 판단한다.

근거 키워드

개인정보 보호법 제28조의8-제28조의10, 제31조의2

시험장에서: 국외 서버에 놓이거나 국외에서 조회 가능하면 먼저 국외이전을 의심한다.

Q25. 국외 이전 조건

문항 오류

정답 결론: ⑤ (출제 의도상)

문제 원문 · 선지

Q25. 개인정보 국외 이전 조건으로 가장 적절하지 않은 것은?

- ① 정보주체에 동의를 받은 경우
- ② 정보주체와의 계약의 체결 및 이행을 위하여 개인정보의 처리위탁·보관이 필요한 경우
- ③ 이전받는 자가 개인정보 보호에 필요한 안전조치 및 정보주체 권리보장에 필요한 조치, 개인정보가 이전되는 국가에서 이행하기 위해 필요한 조치를 수행하여 개인정보 보호 인증을 받은 경우
- ④ 이전되는 국가 또는 국제기구의 보호체계, 정보주체 권리보장 범위, 피해구제 절차 등이 이 법에 따른 보호수준과 실질적으로 동등한 수준을 갖추었다고 보호위원회가 인정하는 경우
- ⑤ 개인정보를 이전받는 자와 표준계약조항(SCC) 을 체결한 경우

문항 오류

⑤의 SCC는 한국법상 독립 허용 근거가 아니어서 틀리다. 그러나 ②도 처리방침 공개 또는 개별 통지라는 추가 조건이 빠져 있어 문장 그대로는 충분한 조건이 아니다. 단일정답 문제로는 완전하지 않다.

STEP BY STEP

- 1 법 제28조의8 제1항의 다섯 경로를 대조한다: 동의, 법률·조약, 계약+공개/통지, 인증+조치, 동등성 인정.
- 2 ⑤의 SCC는 GDPR 제46조상 이전 수단이지 한국법의 독립된 여섯 번째 경로가 아니다.
- 3 ②는 계약 체결·이행 필요성뿐 아니라 법정사항을 처리방침에 공개하거나 정보주체에게 알려야 완성된다.
- 4 출제 의도상 ⑤를 고르되 ②의 누락 조건도 함께 기억한다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	맞음	국외이전에 관한 별도 동의는 허용 근거다.
②	불완전	계약 이행을 위한 위탁·보관에 더해 처리방침 공개 또는 개별 통지가 필요하다.
③	맞음	보호위원회가 정한 인증과 안전조치·권리보장·현지 이행조치를 모두 갖추는 경로다.
④	맞음	보호위원회의 실질적 동등 수준 인정은 독립 허용 근거다.
⑤	정답	SCC 체결만으로 한국 개보법상 국외이전 근거가 완성되지는 않는다.

예랑이랑 통합본 연결

p.39, p.67-69

추가 보강

- 암기: 동-법-계-인-인 = 동의, 법률·조약, 계약, 인증, 인정.
- 계약 경로는 제3자 제공이 아니라 처리위탁·보관에 한정된다는 점도 중요하다.

근거 키워드

개인정보 보호법 제28조의8 · GDPR Article 46

시험장에서: 법정 목록 문제는 빠진 부대조건까지 확인한다.

Q26. 개인정보 처리방침 공개 의무

정상

정답 결론: ③

문제 원문 · 선지

Q26. 다음 중 「개인정보 보호법」 제30조 및 같은 법 시행령이 규정하는 '개인정보처리방침 공개 의무'에 대한 설명으로 가장 부적절한 것은?

- ① 개인정보처리방침은 인터넷 홈페이지 등 이용자가 쉽게 확인할 수 있는 방법으로 상시 공개해야 하며, 내용이 변경될 경우 변경사항과 시행일을 함께 명시해야 한다
- ② 개인정보처리방침에는 개인정보의 수집 항목, 보유 기간, 안전성 확보조치 등을 반드시 포함해야 한다
- ③ 공공기관은 개인정보처리방침 공개 의무가 면제이지만, 정보주체 요구 시 개별 안내 형태로 대체할 수 있다
- ④ '개인정보 보호책임자(CPO) 성명 또는 연락처'를 개인정보처리방침에 기재하지 않으면 과태료 부과 대상이 될 수 있다
- ⑤ 모바일 앱 서비스도 동일한 공개 의무를 적용받으며, 화면 크기 제한 등 기술적 사유를 이유로 공개를 생략할 수 없다.

STEP BY STEP

- 1 제30조의 주어가 모든 개인정보처리자임을 확인한다.
- 2 공공기관은 등록대상 개인정보파일에 대해 처리방침을 정한다는 특칙이 있을 뿐 면제되지 않는다.
- 3 따라서 공공기관 면제를 주장한 ③이 부적절하다.

선지별 판정

선지	판정	해설고 / 해설러는가
①	맞음	홈페이지 등 쉽게 확인할 방법으로 지속적으로 공개하고 변경사항을 알리는 것이 원칙이다.
②	맞음	처리 항목·보유기간·안전성 확보조치 등 법정사항을 포함한다.
③	정답	공공기관도 처리방침 수립·공개 의무가 있다.
④	맞음	CPO 성명 또는 담당부서 명칭과 연락처를 포함해야 하며 위반 시 제재 대상이 될 수 있다.
⑤	맞음	모바일 앱도 예외가 아니며 링크·메뉴 등 쉽게 확인할 수 있는 공개방식을 제공해야 한다.

예랑이랑 통합본 연결

p.12, p.50, p.70

추가 보강

- CPO 개인 직통번호가 아니라 개인정보 보호업무 부서의 연락처를 기재하는 방식도 가능하다.

근거 키워드

개인정보 보호법 제30조 · 개인정보 보호법 시행령 제31조

시험장에서: 공공기관은 면제가 아니라 개인정보파일 등록과 연동된 특칙이 있다.

Q27. 정보주체 권리 보장 조항 매칭

정상

정답 결론: ③

문제 원문 · 선지

Q27. 다음 보기 ㉠~㉤는 '정보주체 권리 보장' 관련 조항을 요약한 것이다. 서로 잘못 연결된 조합을 고르시오.

보기

- ㉠ 열람권 — 개인정보처리자는 열람 요구를 받은 날부터 10일 이내 처리 결과를 통지해야 한다.
- ㉡ 정정·삭제권 — 보존 의무가 있는 경우에도 정보주체 요청 시 즉시 삭제해야 한다.
- ㉢ 처리정지권 — 정지 요청 시 다른 법률에 특별 규정이 있으면 거부할 수 있다.
- ㉤ 손해배상권 — 개인정보처리자가 무과실을 입증하면 책임을 면할 수 있다.

- ① ㉠, ㉡
- ② ㉡, ㉤
- ③ ㉡
- ④ ㉢
- ⑤ ㉤

STEP BY STEP

- 1 각 문장을 권리별 거절 사유와 처리기한에 대조한다.
- 2 법률상 보존의무가 있으면 삭제 요구를 거절할 수 있으므로 ㉡가 틀렸다.
- 3 ㉠·㉢·㉤는 법령 구조와 부합하므로 ㉡만 고른 ③이 정답이다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는지
①	오답	㉠는 맞으므로 ㉠까지 잘못이라고 묶을 수 없다.
②	오답	㉤의 손해배상 책임은 처리자가 고의·과실 없음을 입증하면 면책될 수 있다.
③	정답	법률상 보존의무가 있으면 즉시 삭제가 아니라 삭제 요구를 거절하고 이유를 알려야 한다.
④	오답	다른 법률의 특별 규정은 처리정지 거절 사유가 될 수 있다.
⑤	오답	㉤는 과실 추정과 면책 구조를 요약한 맞는 문장이다.

예랑이랑 통합본 연결

p.12-13, p.54-56

추가 보강

- 열람·정정삭제·처리정지는 권리마다 거절 사유가 다르므로 한 표로 합쳐 외우지 않는다.

근거 키워드

개인정보 보호법 제35조-제39조 · 개인정보 보호법 시행령의 권리행사 절차

시험장에서: 보존의무가 있으면 '삭제'보다 '분리 보관·이용 제한'을 떠올린다.

Q28. 만 14세 미만 아동 개인정보

정상

정답 결론: ⑤

문제 원문 · 선지

Q28. 다음 중 '만 14세 미만 아동' 개인정보 처리에 관한 설명으로 틀린 것은?

- ① 법정대리인의 동의를 받지 않고 아동의 개인정보를 수집하면 과태료 대상이 된다
- ② 개인정보처리자는 만 14세 미만 아동의 개인정보를 처리할 때는 보호자(이하 '법정대리인')의 동의를 받아야 하며, 법정대리인이 동의 하였는지 확인하여야 한다
- ③ 법정대리인 동의받기 위한 법정대리인의 최소한의 정보(성명, 연락처)는 아동으로부터 직접 수집이 가능하다
- ④ 법정대리인의 동의 거부 또는 동의 미확인 시 수집일로부터 5일 이내 파기해야 한다
- ⑤ 아동에 대해 개인정보 수집을 받을 때 법정대리인이 동의했어도 아동의 선택결정권을 위해 아동에게 별도의 동의를 받는 절차를 거쳐야 한다.

STEP BY STEP

- 1 동意的 주체를 본다: 만 14세 미만이면 법정대리인의 동의를 받고 실제 동의 여부를 확인한다.
- 2 법정대리인 동의를 받기 위한 최소 정보는 아동에게 직접 받을 수 있다.
- 3 아동에게는 쉬운 양식과 언어로 고지해야 하지만 별도의 법정 동의를 다시 받을 의무는 없다.
- 4 따라서 ⑤가 틀렸다.

선지별 판정

선지	판정	해 있고 / 왜 틀리는가
①	맞음	필요한 법정대리인 동의를 받지 않은 처리는 과태료 대상이 될 수 있다.
②	맞음	법정대리인 동의와 동의 확인이 모두 필요하다.
③	맞음	법정대리인의 성명·연락처는 동의 확인을 위한 최소정보로 직접 수집할 수 있다.
④	취지상 맞음	동이가 성립하지 않으면 처리 근거가 없어 지체 없이 파기해야 하며 일반적으로 5일 이내 기준을 적용한다.
⑤	정답	법이 요구하는 것은 법정대리인 동의와 아동 눈높이 고지이지 아동의 별도 동의가 아니다.

예랑이랑 통합본 연결

p.12, p.60, p.62

추가 보강

- 아동 눈높이 설명 의무와 아동 본인의 법정 동의는 다른 개념이다.

근거 키워드

개인정보 보호법 제22조의2 · 개인정보 보호법 시행령 제17조의2

시험장에서: 법정대리인=동의, 아동=쉬운 고지로 구분한다.

Q30. 전문 CPO 지정 대상

정상

정답 결론: ⑤

문제 원문 · 선지

Q30. 전문 CPO 제도 적용 대상에 해당하는 기업으로 잘못된 것을 고르시오.

- ① 공공 시스템 운영기관
- ② 연 매출액 1,500억 이상이며 100만 명 이상 개인정보 처리하는 기업
- ③ 연 매출액 1,500억 이상이며 5만 명 민감정보 또는 고유식별정보를 처리하는 기업
- ④ 상급종합병원
- ⑤ 재학생 수 1만 명 이상 대학

STEP BY STEP

- 1 전문 CPO 대상 유형을 공공시스템, 대규모 민간, 상급종합병원, 대학으로 나눈다.
- 2 대학 기준은 대학원 재학생을 포함한 재학생 2만명 이상이다.
- 3 1만명이라고 낮춘 ⑤가 잘못되었다.

선지별 판정

선지	판정	해설고 / 해설하는가
①	맞음	보호위원회가 고시한 기준을 충족하는 공공시스템 운영기관은 대상이 될 수 있다.
②	맞음	매출 1,500억원 이상이면서 100만명 이상 개인정보 처리 기준에 해당한다.
③	맞음	매출 1,500억원 이상이면서 5만명 이상 민감정보·고유식별정보 처리 기준에 해당한다.
④	맞음	대규모 건강정보를 처리하는 상급종합병원은 대상이다.
⑤	정답	대학 기준은 재학생 1만명이 아니라 2만명 이상이다.

예랑이랑 통합본 연결

p.10, p.40, p.51

추가 보강

- 전문 CPO는 개인정보보호 경력 2년 이상을 포함한 합산 경력 요건도 확인한다.

근거 키워드

개인정보 보호법 제31조 · 개인정보 보호법 시행령 제32조

시험장에서: 전문 CPO 숫자: 1,500억-100만 / 1,500억-5만 / 대학 2만.

3과목 · 개인정보 라이프사이클 관리

수집·위탁·광고·AI·파기

수록 문항: Q31, Q32, Q34, Q40, Q43, Q47, Q50

문항 번호 순으로 배열했습니다. 원문 안의 과목 표기는 보존했으며, 이 장의 분류는 전체 시험 번호 구간을 기준으로 정리했습니다.

Q31. 필수 수집 불가 항목 고르기

사실관계 주의

정답 결론: ③ (출제 전제상)

문제 원문 · 선지

Q31. A기업이 「개인정보 보호법」 상 '최소 수집·필수·선택 구분' 원칙을 충족하도록 필수로 받으면 안 되는 항목을 모두 고른 것은? (3과목)

보기

2025년 9월, IoT 스타트업 A기업은 '스마트 도어락' 가입 신청서에 [이름, 휴대폰 번호, 이메일, 설치 주소, 지문, 가족구성원 이름, 가족구성원 휴대폰 번호] 정보를 필수 기재하도록 했다.

A. 설치 주소 B. 지문 C. 가족구성원 이름 D. 가족구성원 휴대폰 번호

- ① A, B
- ② A, B, C
- ③ B, C, D
- ④ A, D
- ⑤ A, C

사실관계 주의

지문은 도어락의 인증 방식과 대체수단을 설명하지 않는다. 지문이 본인 식별용 생체인증을 필수 기능으로 설계했다면 지문의 필요성 판단이 달라질 수 있다. 출제 의도는 설치주소만 계약 필수, 지문·가족정보는 선택 또는 별도 수집이라는 것이다.

STEP BY STEP

- 1 설치 주소 A는 물리적 설치와 계약 이행에 직접 필요하다.
- 2 지문 B는 개인 식별을 위해 처리하면 민감정보이며 비밀번호·카드 등 대체수단이 있으면 가입 필수로 묶기 어렵다.
- 3 가족 이름 C와 휴대폰 D는 제3자의 개인정보이므로 가입자 동의만으로 필수 수집할 수 없다.
- 4 따라서 B·C·D를 고른 ③이 출제 의도상 정답이다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	오답	A 설치 주소는 서비스 이행에 필요하므로 제외해야 한다.
②	오답	A를 포함한 점이 틀리고 D도 빠졌다.
③	정답	B는 민감한 선택정보, C·D는 가족 제3자 정보라는 전제에 맞는다.
④	오답	A를 포함하고 B·C를 누락했다.
⑤	오답	A를 포함하고 B·D를 누락했다.

예랑이랑 통합본 연결

p.45-46, p.59, p.61-64

추가 보강

- 지문은 서비스 대체수단과 목적을 충분히 써야 단일정답이 된다.
- 가족 연락처가 긴급 연락 기능에 필요하다더라도 선택 수집과 가족 본인의 적법한 처리 근거를 따로 설계한다.

근거 키워드

개인정보 보호법 제16조, 제23조

시험장에서: 계약 성립 필요성-민감정보 여부-제3자 정보 여부 순으로 본다.

Q32. 제3자 제공 vs 위수탁

문항 오류

정답 결론: 원 정답 ③은 현행법상 방어 곤란

문제 원문 · 선지

Q32. 다음 보기 중 제3자 제공과 위수탁을 비교 설명한 내용으로 옳은 것만을 모두 고른 조합은?

보기

- ㉠ 제3자 제공은 정보주체 동의를 원칙으로 하나, 위탁은 수탁자 관리·감독이 핵심이며 동의 요건이 다르다.
- ㉡ 위탁 시 수탁자가 자기 명의·책임으로 개인정보를 재이용하면 무단 제3자 제공에 해당한다.
- ㉢ 제3자 제공 기록 보관·열람 의무는 있으나, 위탁 현황 공개 의무는 법령에서 제외된다.
- ㉣ 국외 클라우드에 데이터 저장을 위탁하는 경우, 동시적으로 '국외 이전' 신고가 적용될 수 있다.

① ㉠, ㉢

② ㉠, ㉣

③ ㉠, ㉡, ㉣

④ ㉡, ㉣

⑤ ㉠, ㉡, ㉢, ㉣

문항 오류

㉣의 '국외 이전 신고'는 현행 개인정보 보호법의 일반 절차가 아니다. 국외 클라우드 보관은 국외이전이지만 법정 허용 근거, 공개·통지·동의, 보호조치를 검토하는 것이지 일률적인 사전 신고를 하는 것은 아니다. 따라서 옳은 것은 ㉠·㉡인데 해당 조합이 선지에 없다.

STEP BY STEP

- 1 ㉠: 제3자 제공은 수령자의 목적, 위탁은 위탁자의 목적이라는 구조 차이를 확인한다.
- 2 ㉡: 수탁자가 자기 목적에 재이용하면 위탁 범위를 벗어나 제3자 제공 문제가 생긴다.
- 3 ㉢: 위탁 업무와 수탁자·재수탁자는 공개 대상이므로 틀렸다.
- 4 ㉣: 국외 보관은 국외이전이지만 '신고'가 일반 요건이라는 표현은 틀렸다.
- 5 결론: ㉠·㉡만 옳으나 해당 답지가 없어 문항을 정답불성립으로 처리해야 한다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	오답	㉔가 틀렸다.
②	오답	㉔가 틀리고 ㉔가 빠졌다.
③	원 정답이나 오류	㉔를 맞다고 본 데서 오류가 발생한다.
④	오답	㉔가 빠지고 ㉔가 들어갔다.
⑤	오답	㉔와 ㉔가 모두 틀렸다.

예랑이랑 통합본 연결

p.21, p.23, p.66-70

추가 보강

- 위탁자는 재위탁에 사전 동의하고 재수탁자까지 공개해야 한다.
- 국외이전은 '신고'라는 한 단어로 외우지 말고 허용 근거와 고지·보호조치로 정리한다.

근거 키워드

개인정보 보호법 제26조, 제28조의8

시험장에서: 국외이전 문제에서 '무조건 신고'가 나오면 법 조문에 실제 신고 의무가 있는지 확인한다.

Q34. 영리 목적 광고성 정보

정상

정답 결론: ⑤

문제 원문 · 선지

Q34. 다음 중 수신자에게 전송되는 영리 목적의 광고성 정보에 해당하는 것을 고르시오.

- ① 재화 등의 거래관계를 통하여 수신자로부터 직접 연락처를 수집한 자가 거래관계 종료일부터 6개월간 동종의 거래에 대한 광고 정보
- ② 계약 체결 전 수신자의 요청에 따른 1회성 정보를 전송하는 경우
- ③ 전송자와 수신자 간 체결된 계약이행 등과 관련한 정보
- ④ 공익목적에 위한 광고성 정보
- ⑤ 신용카드 거래내역(결제) 정보를 이메일로 전송하면서 하단에 광고성 정보를 포함하는 경우

STEP BY STEP

- 1 메시지의 주된 목적과 일부에 판촉 내용이 섞였는지 확인한다.
- 2 거래·계약 이행 정보 자체는 광고가 아닐 수 있다.
- 3 그러나 거래내역 메일 하단에 광고를 넣으면 그 광고 부분 때문에 광고성 정보 규율이 적용된다.
- 4 따라서 ⑤가 광고성 정보에 해당한다.

선지별 판정

선지	판정	해설고 / 해설리는가
①	예외	직접 거래로 연락처를 수집한 자가 거래 종료 후 6개월 동안 동종 재화 광고를 보내는 경우 사전동의 예외가 될 수 있다.
②	비광고	수신자가 요청한 1회성 정보는 일반적으로 광고성 정보로 보지 않는다.
③	비광고	계약 이행에 필요한 고지는 판촉 목적이 아니라 거래 정보다.
④	비광고	순수 공익 목적 정보는 영리 목적 광고성 정보가 아니다.
⑤	정답	결제 정보라는 비광고성 본문에 판촉을 끼워 넣어도 광고 규율을 피할 수 없다.

예랑이랑 통합본 연결

p.17, p.57-58

추가 보강

- 2026.7.7 시행 법령에서도 거래 종료 후 6개월 예외가 유지된다.
- 광고와 거래 고지를 한 메시지에 섞지 않는 것이 실무상 안전하다.

근거 키워드

정보통신망법 제50조 · 정보통신망법 시행령 제61조

시험장에서: 하단 배너·쿠폰도 전체 메시지의 광고성 판단에 영향을 준다.

Q40. CloudStream RAG 학습

복수오답 위험

정답 결론: ③이 명백한 오답이나 ②도 부정확

문제 원문 · 선지

Q40. CloudStream의 'RAG 학습' 방식이 「개인정보 보호법」 상 합법적으로 운용되기 위한 필수 보호 조치로 가장 거리가 먼 것은?

보기

2025년 12월, 글로벌 SaaS 기업 CloudStream은 'RAG 기반 문서요약 서비스'를 출시하며, 한국 기업 고객이 업로드한 계약서·인사 파일(개인정보 포함)을 벡터DB에 임베딩해 모델 답변 품질을 개선한다.

- ① 임베딩 전 원문 파일을 가명처리하고, 추가정보를 별도 분리해 저장
- ② 한국 고객 데이터가 저장된 벡터DB의 위치·환경 등을 국외 이전 신고서에 상세 기재
- ③ 한국 고객 데이터가 EU 리전에 저장되므로 한국 개인정보보호법의 안전성 확보조치 고시와 국외이전 요건은 적용되지 않으며, EU GDPR을 준수
- ④ 계약서·인사 파일 원본을 목적 달성 후 지체 없이 삭제하되, 임베딩 벡터에 동일 삭제 주기 적용
- ⑤ 한국 이용자에게 벡터DB 보관 기간·파기 방법·모델 학습 범위를 개인정보처리방침 및 DPA(데이터 처리 부속합의)에 명시

복수오답 위험

③은 EU 리전에 저장돼도 한국법이 배제되지 않으므로 틀리다. 동시에 ②의 '국외 이전 신고서'도 한국 개인정보법의 일반 요건이 아니어서 부정확하다. 단일정답으로는 문제가 있다.

STEP BY STEP

- 1 한국 고객 개인정보를 한국 사업자가 처리하고 국외로 보내면 서버 위치와 무관하게 한국법상 국외이전 규율을 검토한다.
- 2 EU GDPR이 적용되더라도 한국법이 자동 배제되는 것이 아니라 두 규범이 중첩될 수 있다.
- 3 벡터도 개인과 연결되거나 원문 복원·추론 가능성이 있으면 개인정보로 관리하고 보유기간·삭제를 적용한다.
- 4 국외이전은 일반 신고서 제출이 아니라 법정 허용 근거와 공개·통지·동의·보호조치를 갖추는 구조다.

선지별 판정

선지	판정	해설고 / 해설리는가
①	대체로 맞음	가명처리와 추가정보 분리는 위험을 낮추는 핵심 조치다. 다만 RAG의 목적과 필요성도 별도로 검토한다.
②	부정확	국외이전 사실과 항목을 처리방침·통지 등으로 투명하게 알릴 수 있지만 일반적인 '국외 이전 신고서' 제도는 없다.
③	정답 취지	EU 저장은 한국법 적용을 없애지 않는다. GDPR과 한국법을 함께 검토해야 한다.
④	맞음	개인정보성이 남은 임베딩 벡터에도 보유기간과 삭제 정책을 적용해야 한다.
⑤	맞음	보관기간·파기·학습 범위와 위탁관계를 처리방침·계약에서 투명하게 정하는 조치다.

예랑이랑 통합본 연결

p.06, p.39, p.47-48, p.65, p.67-69

추가 보강

- RAG는 보통 검색증강 생성이며 '학습'과 동일하지 않다. 서비스 품질 개선을 위해 입력을 별도 학습에 쓰는지 구분해야 한다.
- 프롬프트·응답로그·임베딩은 각각 개인정보성을 따로 평가한다.

근거 키워드

개인정보 보호법 제26조, 제28조의8, 제29조 · 개인정보보호위원회 AI·가명정보 안내서

시험장에서: 클라우드 지역이 바뀌어도 적용 법률이 하나로 자동 교체되지는 않는다.

Q43. 파기·가명정보·익명정보

복수오답 위험

정답 결론: ④가 출제 의도이나 ⑤도 일반 의무로 보기 어려움

문제 원문 · 선지

Q43. 다음은 '파기·가명정보·익명정보'에 대한 설명이다. 가장 적절하지 않은 것을 고르시오.

- ① 파기란 개인정보를 복구·재생이 불가능하도록 만드는 조치이며, 파기된 개인정보에 대해서는 더 이상 열람·정정·삭제·처리정지권의 대상이 되지 않는다
- ② 가명정보는 추가정보 분리·권한 분리 등 안전조치 의무가 존재한다
- ③ 익명정보는 합리적으로 시간·비용·기술을 고려할 때 재식별이 불가능해야 하며, 이 기준을 충족한 경우에 한해 개인정보보호법 적용 대상이 아니다
- ④ 가명정보는 통계·연구 이외 목적에는 활용할 수 없으므로, 사적 이익을 위한 상업적 활용 목적으로 활용할 수 없다
- ⑤ 파기 대신 익명처리를 선택하는 경우, 개인정보 처리방침에 익명처리의 기준·방법을 포함해 고지하고, 내부관리계획에는 익명처리 절차·책임 및 재식별 방지·검증·기록관리 등을 반영하여야 한다.

복수오답 위험

④는 상업적 과학연구도 가능하므로 틀리다. 그러나 ⑤의 '익명처리 기준·방법을 처리방침에 반드시 고지하고 내부관리계획에 반드시 반영'한다는 보편적 의무는 현행 법정 필수항목에서 직접 확인되지 않는다. ⑤는 권고 가능한 좋은 관리방안이지 일반적 법정 의무라고 단정하기 어렵다.

STEP BY STEP

- 1 가명정보는 개인정보이고, 익명정보는 합리적 시간·비용·기술을 고려해 더 이상 개인을 알아볼 수 없는 정보다.
- 2 과학적 연구 정의에는 기술개발·실증·응용연구·민간 투자 연구가 포함된다.
- 3 따라서 사적 이익이 있다는 이유만으로 가명정보 활용이 금지된다는 ④는 틀렸다.
- 4 ⑤는 법정 의무와 모범 관리조치를 혼동하므로 문항 자체에 추가 오류가 있다.

선지별 판정

선지	판정	해설고 / 해설리는가
①	맞음	복구·재생 불가능하게 파기하면 더 이상 처리 중인 개인정보가 없어 권리행사 대상도 사라진다.
②	맞음	가명정보도 추가정보 분리·접근권한·기록 등 안전조치가 필요하다.
③	맞음	합리적 수단으로 재식별할 수 없는 정보에만 법 적용 제외가 인정된다.
④	정답 취지	상업적·산업적 연구도 과학적 방법을 쓰면 과학적 연구에 포함될 수 있다.
⑤	부정확	익명처리 절차를 문서화하는 것은 바람직하지만 처리방침·내부관리계획의 일반 필수항목이라고 단정하기 어렵다.

예랑이랑 통합본 연결

p.08, p.20, p.47-48, p.65, p.82

추가 보강

- 가명정보는 개인정보 보호법 적용 대상이고 익명정보는 요건을 충족할 때 적용 제외다.
- 상업성 자체보다 과학적 방법·목적 적합성과 재식별 위험이 핵심이다.

근거 키워드

개인정보 보호법 제2조 제8호, 제28조의2-제28조의7, 제58조의2

시험장에서: 가명=법 적용, 익명=요건 충족 시 법 적용 제외로 먼저 가른다.

Q47. MarketQ 위탁 관리·감독

조치 보완 필요

정답 결론: ① (가장 가까움)

문제 원문 · 선지

Q47. MarketQ가 위탁 관리·감독 의무를 준수하기 위해 가장 먼저 실시해야 할 조치로 가장 적절한 것을 고르시오.

보기

온라인 장터 MarketQ는 2025년 10월, 물류 스타트업 ShipOn에게 구매자 이름·주소·연락처를 실시간 API로 전송해 배송 서비스를 운영한다. ShipOn은다시 지역 택배사 LocalDrop에게 동일 데이터를 전송한다.

- ① ShipOn·LocalDrop 간 재위탁 계약 체결 여부를 확인하고, LocalDrop을 수탁자 목록에 공개한다
- ② ShipOn이 LocalDrop과 재위탁 계약을 체결하도록 안내하고, MarketQ는 관계가 없으므로 추가 조치는 별도로 하지 않는다
- ③ API 전송 시 SSL/TLS 등 암호화 적용 여부를 ShipOn이 결정하도록 권한을 위임한다
- ④ 배송 완료 후 3개월 내 ShipOn·LocalDrop이 개인정보를 파기했는지 현장 실사를 통해 점검한다
- ⑤ 수탁자인 ShipOn이 ISO 27001, ISMS-P 인증을 보유한 경우, MarketQ는 별도의 정기 점검·감독 없이도 위탁 관리·감독 의무를 이행한 것으로 본다.

조치 보완 필요

①은 가장 적절하지만 '재위탁 계약 확인+공개'만으로 충분하지 않다. ShipOn은 재위탁 전에 MarketQ의 동의를 받아야 하고, MarketQ는 LocalDrop까지 감독 범위에 넣어야 한다.

STEP BY STEP

- 1 ShipOn이 LocalDrop에 넘긴 행위가 배송 위탁 목적 안의 재위탁인지 확인한다.
- 2 MarketQ의 사전 동의와 재위탁 문서, 목적·범위·안전조치·파기 조건을 확인한다.
- 3 재수탁자 LocalDrop을 포함해 위탁 업무와 수탁자 현황을 공개한다.
- 4 이후 암호화·접근통제·파기·교육·정기 점검을 수행한다.

선지별 판정

선지	판정	해설고 / 해설리유
①	정답	재위탁의 법적 상태와 공개를 먼저 바로잡는 조치다. 다만 위탁자 동의 확인도 포함해야 완전하다.
②	오답	원 위탁자 MarketQ는 재위탁 동의·공개·관리감독 책임에서 벗어나지 않는다.
③	오답	암호화 등 안전조치는 위탁계약과 감독 범위에 두어야 하며 전적으로 수탁자 자율에 맡길 수 없다.
④	후순위	파기 현장점검은 필요할 수 있지만 재위탁의 적법성부터 확인해야 하며 '3개월'이라는 일률 기한 근거도 없다.
⑤	오답	인증 보유는 감독을 면제하지 않는다.

예랑이랑 통합본 연결

p.21, p.23, p.66, p.69-70

추가 보강

- 법 제26조의 수탁자에는 재수탁자도 포함된다.
- 재위탁은 위탁자의 동의-문서화-공개-감독 순서로 관리한다.

근거 키워드

개인정보 보호법 제26조

시험장에서: 재위탁을 보면 원 위탁자의 사전 동의와 재수탁자 공개를 동시에 떠올린다.

Q50. 스마트카 국경 간 최소 이전

설계 판단 주의

정답 결론: ④ (출제 의도상)

문제 원문 · 선지

Q50. A기업이 '국경 간 데이터 최소 이전·최소 보존' 원칙을 충족하기 위한 최우선 기술·관리 대책으로 가장 적절하지 않은 것을 고르시오.

보기

2025년 12월, 스마트카 플랫폼 A기업은 차량 내부 카메라로 운전자 표정·시선 데이터를 실시간 수집해 '졸음·주의 분산' 탐지 모델을 운영한다. A기업은 데이터 분석·모델 개선을 위해 30일간 영상·시선 좌표·차량 속도 로그를 미국 리전 GPU 팜에 저장한다.

- ① 운전자 영상 데이터를 디바이스(Local Edge)에서 가명처리 후, 시선 좌표·졸음 확률 값만 전송해 모델 업데이트
- ② 미국 리전 저장 로그를 30일 후 자동 파기하고, 모델 성능 로그는 가명화 후 미국 리전에 백업
- ③ 실시간 전송 중 영상 스트림을 TLS 1.3 이상으로 암호화하고, 전송 종료 후 세션 키를 폐기
- ④ 차량-클라우드 간 데이터 전송 빈도를 줄이기 위해, 데이터 동기화 주기를 24시간 단위로 일괄 배치
- ⑤ 미국 리전 GPU 팜 내 VM을 '기밀컴퓨팅(TEE)' 환경으로 구현해, 처리 중 데이터 암호화를 구현

설계 판단 주의

④는 전송 횟수만 줄이고 총 이전량·보존량을 줄이지 않아 최소 이전 대책으로 약하다. 다만 배치 전송 자체가 항상 부적절한 것은 아니다. ②의 미국 백업도 필요성과 보유기간이 입증되지 않으면 최소보존에 반할 수 있다.

STEP BY STEP

- 1 최소 이전은 전송 빈도보다 전송하는 데이터 종류와 총량을 줄이는 문제다.
- 2 로컬에서 영상 대신 파생값만 만들면 원본의 국외이전을 크게 줄일 수 있다.
- 3 TLS와 TEE는 전송 중·처리 중 기밀성을 높이지만 데이터 양 자체를 줄이지는 않는다.
- 4 24시간 일괄 배치는 같은 양을 늦춰 보내는 방식이므로 최소 이전의 최우선 대책이 아니다.

선지별 판정

선지	판정	해 맞고 / 해 풀리는가
①	맞음	로컬 처리와 가명·파생값 전송은 원본 영상의 국외 이전량을 줄인다.
②	조건부	자동 파기와 가명화는 좋지만 미국 백업의 목적·기간·필요성을 별도 입증해야 한다.
③	맞음	TLS와 세션키 폐기는 전송 중 노출 위험을 낮춘다.
④	정답	전송 횟수만 줄일 뿐 총량과 보존량을 줄이지 않는다.
⑤	맞음	TEE는 처리 중 데이터 노출 위험을 낮추는 보완조치다.

예랑이랑 통합본 연결

p.08, p.20, p.36-37, p.65, p.67-68, p.72, p.78-79

추가 보강

- 최소화와 보안은 다르다: 암호화는 같은 데이터를 안전하게 보내고, 로컬 처리는 보낼 데이터를 줄인다.
- 생체인식정보 해당 여부는 개인 식별 목적으로 기술적 처리를 하는지에 달려 있다.

근거 키워드

개인정보 보호법 제3조, 제16조, 제21조, 제25조의2, 제28조의8

시험장에서: 빈도·암호화·총량을 서로 다른 축으로 구분한다.

4과목 · 개인정보 보호조치

내부관리계획·웹보안·암호화·네트워크

수록 문항: Q56, Q57, Q58, Q59, Q61, Q62, Q65

문항 번호 순으로 배열했습니다. 원문 안의 과목 표기는 보존했으며, 이 장의 분류는 전체 시험 번호 구간을 기준으로 정리했습니다.

Q56. 내부 관리계획

시행일 주의

정답 결론: ⑤

문제 원문 · 선지

Q56. 다음 중 '내부 관리계획' 수립·시행에 대한 설명으로 가장 적절하지 않은 것은? (4과목)

- ① 개인정보처리자는 개인정보 보호책임자 및 개인정보취급자를 대상으로 사업규모, 개인정보 보유 수, 업무성격 등에 따라 차등화하여 필요한 교육을 정기적으로 실시하여야 한다
- ② 내부 관리계획에는 개인정보 보호에 관한 책임·권한, 물리·논리 접근통제, 사고 대응 절차 등을 포함해야 한다
- ③ 개인정보 보호책임자는 접근 권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 내부 관리계획의 이행 실태를 연 1회 이상 점검·관리하여야 한다
- ④ 내부 관리계획에 중요한 변경이 있는 경우에는 이를 즉시 반영하여 내부 관리계획을 수정하여 시행하고, 그 수정 이력을 관리하여야 한다
- ⑤ 10만명 미만의 정보주체에 관하여 개인정보를 처리하는 소상공인·개인·단체의 경우에는 내부 관리계획 수립 및 시행을 생략할 수 있다.

시행일 주의

면제 기준은 10만명 미만이 아니라 1만명 미만이다. 2025.10.31 개정 중 일부 내부관리계획·접속기록 조항은 2026.10.31부터 시행되므로 시험 공고의 법령 기준일을 확인한다.

STEP BY STEP

- 1 내부관리계획의 수립, 교육, 변경 이력, 연 1회 이행점검 의무를 각각 확인한다.
- 2 소규모 예외는 소상공인·개인·단체이면서 1만명 미만 처리라는 좁은 요건이다.
- 3 ⑤가 숫자를 10만명으로 바꾸었으므로 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는지
①	맞음	규모·보유수·업무성격에 맞춘 정기 교육이 필요하다.
②	맞음	책임·권한, 접근통제, 사고 대응 등 핵심 안전조치를 내부관리계획에 담는다.
③	맞음	CPO는 이행실태를 연 1회 이상 점검·관리한다.
④	맞음	중요 변경은 즉시 반영하고 수정 이력을 관리한다.
⑤	정답	예외 기준은 10만명 미만이 아니라 1만명 미만이다.

예랑이랑 통합본 연결

p.27, p.73-74, p.84

추가 보강

- 1만명 미만이라는 숫자만으로 면제되는 것이 아니라 소상공인·개인·단체 요건도 함께 충족해야 한다.

근거 키워드

개인정보의 안전성 확보조치 기준 제4조 및 부칙

시험장에서: 내부관리계획 면제 숫자는 1만명 미만이다.

Q57. 웹 공격 유형 ↔ 방어 기법

정상

정답 결론: ⑤

문제 원문 · 선지

Q57. 다음 보기 ㉠~㉤를 '웹 공격 유형'과 '주요 방어 기법'으로 올바르게 연결한 것은? 공격 유형 방어 기법 ㉠ SQL Injection ㉡ 입력값 검증(Prepared Statement) ㉢ XSS ㉣ SameSite 쿠키·토큰 방식 검증 ㉤ CSRF ㉥ 콘텐츠 보안정책(CSP) 헤더 설정 ㉦ BruteForce Attack ㉧ CAPTCHA/다중인증

① ㉠-㉡, ㉢-㉣, ㉤-㉥, ㉦-㉧

② ㉠-㉡, ㉢-㉣, ㉤-㉥, ㉦-㉧

③ ㉠-㉣, ㉢-㉤, ㉥-㉦, ㉧-㉨

④ ㉠-㉤, ㉢-㉣, ㉥-㉦, ㉧-㉨

⑤ ㉠-㉡, ㉢-㉤, ㉥-㉣, ㉦-㉧

STEP BY STEP

- 1 공격이 어디를 조작하는지 본다: DB 질의, 브라우저 스크립트, 사용자 세션, 비밀번호 시도.
- 2 SQL Injection은 매개변수 바인딩, XSS는 출력 인코딩·CSP, CSRF는 CSRF 토큰·SameSite, Brute Force는 속도 제한·CAPTCHA·MFA로 대응한다.
- 3 모두 맞게 연결한 ⑤를 고른다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	오답	XSS·CSRF·Brute Force 방어가 뒤섞였다.
②	오답	XSS와 CSRF 방어가 서로 바뀌었다.
③	오답	SQL Injection에 SameSite를, CSRF에 Prepared Statement를 연결했다.
④	오답	SQL Injection과 CSRF 연결이 틀렸다.
⑤	정답	Prepared Statement-CSP-SameSite/토큰-CAPTCHA/MFA 연결이 모두 맞다.

예랑이랑 통합본 연결

직접 수록 부족; p.75-81의 접근통제·악성프로그램 파트와 연결

추가 보강

- CSP만으로 XSS가 완전히 막히는 것은 아니며 출력 인코딩과 입력 검증을 함께 쓴다.
- SameSite만으로 CSRF를 완전히 막지 말고 토큰과 Origin 검증을 병행한다.

근거 키워드

OWASP SQL Injection, XSS, CSRF, Authentication Cheat Sheets

시험장에서: DB-브라우저-세션-비밀번호 순으로 공격 표면을 매칭한다.

Q58. 일방향 암호화(해시) 대상

정상

정답 결론: ①

문제 원문 · 선지

Q58. 다음 중 일방향 암호화(해시)의 대상으로 가장 적절한 것은?

- ① 비밀번호
- ② 주민등록번호
- ③ 계좌번호
- ④ 여권번호
- ⑤ 외국인등록번호

STEP BY STEP

- 1 복호화가 필요한 정보인지 먼저 묻는다.
- 2 비밀번호는 원문을 돌려받을 필요 없이 입력값의 일치 여부만 확인하면 된다.
- 3 주민번호 · 계좌 · 여권 · 외국인등록번호는 업무상 원문 확인이 필요할 수 있어 복호화 가능한 안전한 암호화를 사용한다.
- 4 따라서 ①이 일방향 암호화 대상이다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	정답	비밀번호는 소금값과 느린 비밀번호 해시 함수로 검증용 해시를 저장한다.
②	오답	주민등록번호는 필요 시 복호화 가능한 암호화 대상이다.
③	오답	계좌번호는 업무 처리상 원문이 필요할 수 있어 가역 암호화를 쓴다.
④	오답	여권번호도 가역 암호화 대상이다.
⑤	오답	외국인등록번호도 가역 암호화 대상이다.

예랑이랑 통합본 연결

p.28, p.78-79

추가 보강

- 비밀번호에는 일반 해시가 아니라 Argon2id · scrypt · bcrypt · PBKDF2 같은 비밀번호 전용 KDF와 salt를 사용한다.

근거 키워드

개인정보의 안전성 확보조치 기준 제7조 · OWASP Password Storage Cheat Sheet

시험장에서: 다시 읽어야 하면 암호화, 일치만 확인하면 해시.

Q59. MedPark 랜섬웨어 재발방지

정상

정답 결론: ④

문제 원문 · 선지

Q59. MedPark가 재발 방지를 위해 시행해야 할 조치로 가장 적절하지 않은 것은?

보기

2025년 8월, 지방의료원 MedPark는 랜섬웨어 감염으로 환자 진료영상 3TB가 암호화됐다. 조사 결과, 백업 서버는 동일 네트워크 대역에 존재했고 SMB(Server Message Block) 포트가 개방돼 있었다.

- ① 백업 시스템을 운영망과 분리(전용 VLAN/망분리·오프사이트)한다
- ② 랜섬웨어의 측면 이동(lateral movement)을 제한하기 위해 SMB 접근을 허용 IP만 열어 차단·제어한다
- ③ 오프사이트/오프라인 백업 도입 및 정기 복구 테스트를 실시한다
- ④ SMB 포트를 폐쇄하되, 동일 네트워크 세그먼트 구조는 유지해 운영 효율을 확보한다
- ⑤ WORM(Write Once, Read Many) 등으로 보존기간 내 삭제·수정 금지 정책을 적용한다.

STEP BY STEP

- 1 원인을 두 개로 나눈다: 동일 세그먼트와 열린 SMB가 측면 이동을 허용했고 백업이 운영망과 함께 감염됐다.
- 2 백업 격리, 최소 허용 SMB, 오프라인·오프사이트 사본, 복구 테스트를 적용한다.
- 3 포트만 닫고 동일 세그먼트를 유지하는 ④는 구조적 원인을 남긴다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	맞음	운영망과 백업망 분리는 랜섬웨어의 동시 감염을 줄인다.
②	맞음	SMB를 허용 IP와 필요한 흐름으로 제한하면 측면 이동을 줄인다.
③	맞음	오프라인·오프사이트 백업과 복구 테스트는 실제 복구 가능성을 확인한다.
④	정답	포트 폐쇄만으로 동일 세그먼트의 다른 이동 경로와 단일 장애영역을 해결하지 못한다.
⑤	맞음	WORM·불변 백업은 공격자의 삭제·변조를 어렵게 한다.

예랑이랑 통합본 연결

p.75-81의 접근통제·악성프로그램·백업 관련 내용과 연결

추가 보강

- 3-2-1-1-0 백업 원칙: 3개 사본, 2개 매체, 1개 외부, 1개 오프라인/불변, 0개 복구오류를 목표로 한다.

근거 키워드

개인정보 보호법 제29조 · 개인정보의 안전성 확보조치 기준

시험장에서: 포트 차단은 전술, 네트워크 분리와 불변 백업은 구조적 대책이다.

Q61. VPN + 내부망 다중 접근통제

위험기반 주의

정답 결론: ③ (일반적 고위험 구성)

문제 원문 · 선지

Q61. 원격근무 환경에서 VPN과 내부망 간 '다중 접근통제' 정책을 수립하려 한다. 다음 중 가장 적절하지 않은 구성은?

- ① 사내 리소스별 RBAC(Rule Based Access Control) + VPN 접속 시 MFA(Multi-Factor Authentication) 적용
- ② VPN 게이트웨이를 DMZ(Demilitarized Zone)에 배치하고, 내부망으로는 2단계 방화벽을 구성
- ③ VPN 클라이언트에서 Split-Tunneling 기능을 활성화해 인터넷 속도를 최적화
- ④ 접속 로그는 중앙 SIEM(Security Information and Event Management)으로 실시간 전송하고, 무결성 검증을 위한 해시 체인을 적용
- ⑤ VPN 사용자 계정은 주기적으로 권한 검토를 수행하고, 장기 미사용 계정은 즉시 비활성화

위험기반 주의

Split tunneling은 무조건 금지되는 기술이 아니다. 단말 보안, 목적지 제한, DNS·프록시 통제, EDR·DLP 등을 갖춰 위험을 관리할 수 있다. 다만 문제의 '다중 접근통제' 목표에서 아무 조건 없이 활성화한 ③이 가장 부적절하다.

STEP BY STEP

- 1 원격 단말이 VPN과 인터넷에 동시에 연결되는 경로를 그린다.
- 2 Split tunneling을 켜면 감염 단말이 인터넷과 내부망 사이의 우회 통로가 될 수 있다.
- 3 RBAC·MFA·DMZ·이중 방화벽·SIEM·권한 검토는 통제를 겹쳐 위험을 낮춘다.
- 4 따라서 제한 조건 없는 ③이 가장 부적절하다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	맞음	역할 기반 최소권한과 MFA를 결합한다.
②	맞음	VPN 종단을 DMZ에 두고 내부망 경계를 추가 통제한다.
③	정답	속도만을 이유로 분할 터널을 무조건 활성화하면 우회·유출 위험이 커진다.
④	맞음	중앙 로그와 무결성 보호는 탐지와 책임추적성을 높인다.
⑤	맞음	정기 권한 검토와 미사용 계정 비활성화는 권한 누적을 막는다.

예랑이랑 통합본 연결

p.75-80의 접근통제·접속기록과 연결

추가 보강

- RBAC의 표준 명칭은 Role-Based Access Control이다. 선지의 Rule Based는 용어 오류지만 취지는 역할 기반 통제로 읽는다.

근거 키워드

NIST SP 800-46 · 개인정보의 안전성 확보조치 기준 제5조-제6조

시험장에서: VPN은 암호화 통로이지 최소권한·단말신뢰·망분리를 자동 제공하지 않는다.

Q62. VPN 설명

정상

정답 결론: ③

문제 원문 · 선지

Q62. VPN(Virtual Private Network)에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① Site-To-Site VPN은 두 네트워크 간 터널을 구성하여 지사--본사 간 트래픽을 보호한다
- ② 원격접속 VPN은 개인 단말과 사내망 사이에 터널을 구성하며, 단말 보안상태 점검(NAC 등)과 MFA를 연계하는 것이 바람직하다
- ③ VPN 터널을 사용하면 내부망 접속 권한이 자동으로 최소권한으로 부여된다
- ④ Split-Tunneling 허용 시 인터넷 경로로 유출될 수 있는 트래픽에 대한 위험평가·차단정책이 필요하다
- ⑤ VPN 자격증명·인증서의 분실·도난에 대비해 신속한 폐지·교체 절차를 운영해야 한다.

STEP BY STEP

- 1 VPN이 제공하는 기능을 '암호화된 터널'로 한정한다.
- 2 누가 어디까지 접근하는지는 별도의 인증·권한·방화벽·세분화 정책이 결정한다.
- 3 터널만으로 최소권한이 자동 부여된다는 ③이 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	맞음	Site-to-Site VPN은 두 네트워크 구간을 연결한다.
②	맞음	원격접속 VPN에는 단말상태 점검과 MFA를 결합하는 것이 바람직하다.
③	정답	VPN 연결과 최소권한 부여는 별개의 통제다.
④	맞음	Split tunneling은 인터넷 우회경로의 위험평가와 통제가 필요하다.
⑤	맞음	자격증명·인증서 탈취에 대비한 폐지·교체 절차가 필요하다.

예랑이랑 통합본 연결

p.75-80

추가 보강

- VPN 이후에도 애플리케이션 권한, 네트워크 ACL, 세션 제한을 따로 적용한다.

근거 키워드

NIST SP 800-46

시험장에서: 터널=통신 보호, 권한=접근 결정.

Q65. 물리적 보호조치 및 CCTV

정상

정답 결론: ⑤

문제 원문 · 선지

Q65. 다음 중 물리적 보호조치 및 CCTV 운영 기준을 위반한 사례로 보기 가장 어려운 것은?

- ① CCTV 모니터링 룸 출입 권한을 경비업체 파견 인원에게 24시간 상시 부여하였다
- ② 사무실 내 휴게실 내부에 고정형 CCTV를 설치하고 녹음 기능을 활성화하였다
- ③ CCTV 설치 안내판이 눈에 띄지 않는 위치에 있으며, 설치 목적이나 담당자 정보가 누락되어 있다
- ④ 퇴직한 외부 위탁업체 직원의 접근 권한을 회수하지 않아 CCTV 영상 열람이 가능했다
- ⑤ 직원의 퇴근 시간 이후에는 CCTV 영상에 접근할 수 없도록 시스템을 설정하고 있으며, 접속 기록을 2년간 보관하고 있다.

STEP BY STEP

- 1 물리적 출입권한, CCTV 녹음 금지, 안내판, 퇴직자 권한 회수를 차례로 본다.
- 2 ①-④는 과도한 권한·녹음·안내 누락·권한 미회수라는 명확한 위험이 있다.
- 3 ⑤는 접근시간 제한과 2년 로그 보관이라는 강화 조치이므로 위반으로 보기 어렵다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	위반 가능	파견인력에게 필요성 검토 없이 24시간 상시 권한을 주면 최소권한에 반한다.
②	위반	고정형 CCTV의 녹음 기능 사용은 금지된다. 휴게실 촬영도 목적·필요성·근로자 사생활을 엄격히 검토해야 한다.
③	위반	쉽게 알아볼 수 있는 안내판과 법정 기재사항이 필요하다.
④	위반	퇴직·계약종료 시 접근권한을 지체 없이 회수해야 한다.
⑤	정답	업무시간 밖 접근을 차단하고 기록을 보관하는 것은 보호를 강화한다.

예랑이랑 통합본 연결

p.47, p.74-80, p.82-84

추가 보강

- CCTV 접속기록의 구체 보관기간은 시스템이 처리하는 정보 규모·민감정보 여부 등 적용 기준을 함께 확인한다.

근거 키워드

개인정보 보호법 제25조, 제29조 · 개인정보의 안전성 확보조치 기준

시험장에서: 녹음은 금지, 권한은 최소, 퇴직 시 즉시 회수.

5과목 · 개인정보 관리체계

공공시스템·ISMS-P·국제인증·PIA·위치정보

수록 문항: Q82, Q83, Q86, Q87, Q88, Q89, Q90, Q93, Q94, Q95, Q96, Q97, Q98

문항 번호 순으로 배열했습니다. 원문 안의 과목 표기는 보존했으며, 이 장의 분류는 전체 시험 번호 구간을 기준으로 정리했습니다.

Q82. 공공시스템운영기관 안전조치

정상

정답 결론: ③

문제 원문 · 선지

Q82. 다음 중 「개인정보의 안전성 확보조치 기준」에 따라 공공시스템 운영기관이 준수해야 할 사항으로 가장 적절한 것은?

보기

지방자치단체 산하 기관인 C시는 '민원24 시스템', '보육포털' 등 여러 개의 공공시스템을 운영 중이다.

- ① 공공시스템 운영기관은 전체 기관 단위로 내부관리계획을 통합 수립하면 된다
- ② 공공시스템 운영기관은 접근기록을 수동으로 점검하되, 연 1회 이상만 실시하면 된다
- ③ 공공시스템 운영기관은 각 공공시스템별로 내부관리계획을 별도로 수립·시행해야 한다
- ④ 공공시스템 운영기관은 접근 권한 부여, 변경 또는 말소 내역 등을 반기별 1회 이상 점검하여야 한다
- ⑤ 공공시스템 운영기관은 정보주체 수가 적은 경우 안전조치 기준을 일부 생략할 수 있다.

STEP BY STEP

- 1 먼저 해당 시스템이 공공시스템 안전조치 특례 대상인지 확인한다.
- 2 운영기관은 기관 공통 문서 하나로 끝내지 않고 각 공공시스템의 위험·권한·접속기록 구조를 반영한 내부관리계획을 수립·시행한다.
- 3 접근권한과 접속기록은 자동화된 점검과 월 단위 관리 등 일반 기관보다 강화된 통제를 적용한다.
- 4 따라서 ③이 가장 적절하다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	오답	공공시스템별 특성과 위험을 반영해야 하므로 기관 단위 통합문서만으로 충분하지 않다.
②	오답	수동·연 1회만으로는 강화된 상시·정기 점검 요구를 충족하지 못한다.
③	정답	각 공공시스템별 내부관리계획을 수립·시행하는 취지와 맞다.
④	오답	접근권한 부여·변경·말소 내역은 반기 1회보다 더 엄격하게 점검한다.
⑤	오답	공공시스템 특례는 규모가 작다는 이유만으로 임의 생략할 수 없다.

예랑이랑 통합본 연결

p.27, p.73-74, p.79-80, p.82-83

추가 보강

- 예랑이랑 통합본은 대상 판별은 다루지만 대상이 된 뒤의 제15조-제17조 조치를 충분히 설명하지 않아 보강했다.
- 2026.7.1 개정 고시 중 일부 공공시스템 조항은 2027.1.1 시행이므로 기준일을 확인한다.

근거 키워드

개인정보의 안전성 확보조치 기준 제14조-제17조 및 부칙

시험장에서: 공공시스템은 '기관 하나'가 아니라 '시스템별 위험'을 기준으로 본다.

Q83. 접속기록 보관 기준

중대한 기준일 오류

정답 결론: 2026.8.15 기준 ②와 ③ 모두 맞을 수 있음

문제 원문 · 선지

Q83. 「개인정보의 안전성 확보조치 기준」에 따른 접속기록 보관 기준으로 가장 올바른 것은?

보기

A기업은 개인정보처리시스템에 접근한 기록(로그)을 보관하고 있으며, 최근 처리 정보의 양이 증가해 6만 명 규모 정보주체의 개인정보를 처리하기 시작했다.

- ① 접속기록은 모든 개인정보처리자에게 3년 이상 보관이 의무이다
- ② 5만 명 이상의 정보주체 처리 또는 민감정보·고유식별정보 처리 시 접속기록은 2년 이상 보관해야 한다
- ③ 접속기록에 대해서 월 1회 이상 점검하여야 한다
- ④ 접속기록은 개인정보 파기 후에도 3년 추가로 보관해야 한다
- ⑤ 고유식별정보를 처리하지 않기 때문에 일반적으로는 보관 의무가 없다.

중대한 기준일 오류

②의 2년 보관 기준은 맞다. 또한 월 1회 이상 점검을 폐지하고 내부관리계획 자율주기로 바꾸는 제8조 제2항 개정은 2026.10.31 시행이므로, 2026.8.15 현재는 ③도 맞다. 따라서 현재 기준 단일정답은 성립하지 않는다.

STEP BY STEP

- 1 보관기간: 원칙 1년, 5만명 이상 또는 민감정보·고유식별정보 처리 시스템 등은 2년 이상이다.
- 2 점검주기: 개정 전 규정은 월 1회 이상이다.
- 3 2025.10.31 개정은 주기·방법·사후조치를 내부관리계획으로 정하게 했지만 제8조 제2항 시행일은 2026.10.31이다.
- 4 따라서 2026.8.15 기준 ②와 ③이 동시에 맞고, 2026.10.31 이후라면 ②만 맞는 구조가 된다.

선지별 판정

선지	판정	해설 / 해설이유
①	오답	모든 처리자에게 3년을 요구하지 않는다.
②	맞음	5만명 이상 또는 민감정보·고유식별정보 처리 시스템은 2년 이상 보관한다.
③	기준일에 따라 맞음	2026.10.30까지는 일반적으로 월 1회 이상 점검 규정이 적용된다. 2026.10.31부터 자율주기 체계로 바뀐다.
④	오답	개인정보 파기 뒤 일률적으로 3년을 추가 보관하는 규정은 없다.
⑤	오답	고유식별정보를 처리하지 않아도 접속기록 보관 의무는 존재한다.

예랑이랑 통합본 연결

p.29, p.74, p.79-80, p.92

추가 보강

- 시험 공고가 정한 법령 기준일이 2026.10.31 전인지 후인지 반드시 확인한다.
- 공공시스템운영기관의 별도 월 1회 점검 의무와 일반 처리자 규정을 구분한다.

근거 키워드

개인정보의 안전성 확보조치 기준 제8조 · 개인정보보호위원회고시 제2025-9호 부칙

시험장에서: 숫자뿐 아니라 시행일을 문제 옆에 함께 적는다: 2026-10-31.

Q86. ISMS-P 추진체계

정상

정답 결론: ②

문제 원문 · 선지

Q86. 다음 중 ISMS-P 인증제도에 대한 설명으로 가장 적절하지 않은 것은? (5과목)

- ① 인증기관은 한국인터넷진흥원(KISA)이며, 인증업무의 총괄·관리를 담당한다
- ② 심사기관은 인증기관으로부터 지정을 받아 실제 심사업무를 수행하는 기관이다
- ③ ISMS-P 정책기관에는 과학기술정보통신부와 개인정보보호위원회가 포함된다
- ④ 인증기관은 신청기관이 수립·운영하는 관리체계를 인증기준에 따라 심사하고, 인증위원회를 운영하여 인증기준에 적합한 기관에게 인증서를 발급한다
- ⑤ 인증위원회는 인증심사 결과가 인증기준에 적합한지 여부, 인증 취소에 관한 사항, 이의신청에 관한 사항 등을 심의·의결한다.

STEP BY STEP

- 1 기관 역할을 정책-인증-심사로 나눈다.
- 2 과기정통부와 개인정보위가 정책기관으로서 인증기관·심사기관을 지정한다.
- 3 인증기관은 인증위원회 운영과 인증서 발급을, 심사기관은 실제 심사업무를 수행한다.
- 4 심사기관을 인증기관이 지정한다고 한 ②가 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	맞음	KISA는 법정 인증기관으로 인증업무를 총괄·관리한다. 금융분야에는 금융보안원도 인증기관으로 활동한다.
②	정답	심사기관의 지정 주체는 인증기관이 아니라 정책기관이다.
③	맞음	과기정통부와 개인정보위가 공동 정책기관이다.
④	맞음	인증기관은 심사·인증위원회·인증서 발급 업무를 수행한다.
⑤	맞음	인증위원회는 적합 여부, 취소, 이의신청 등을 심의·의결한다.

예랑이랑 통합본 연결

p.31, p.86-89

추가 보강

- 인증기관도 직접 심사를 수행할 수 있지만 '심사기관 지정권자'가 되는 것은 아니다.

근거 키워드

정보통신망법 제47조 · 개인정보 보호법 제32조의2 · ISMS-P 인증 등에 관한 고시

시험장에서: 정책기관이 지정, 인증기관이 발급, 심사기관이 심사.

Q87. ISMS-P 기대효과

정상

정답 결론: ②

문제 원문 · 선지

Q87. 다음 중 ISMS-P 인증 취득 시 기대효과에 대한 설명으로 가장 적절하지 않은 것은?

- ① ISMS-P 인증기준은 '1. 관리체계 수립 및 운영(16개)', '2. 보호대책 요구사항(64개)', '3. 개인정보 처리단계별 요구사항(21개)'으로 구성되어 있다
- ② ISMS-P 인증을 받은 기업(조직)은 정보보안 침해사고로부터 안전하다는 것을 보장하는 제도이다
- ③ ISMS-P 인증을 취득한 기관은 정보보호 및 개인정보보호에 대한 신뢰성을 높여 대외 이미지를 제고할 수 있다
- ④ 기업 경영진이 직접 정보보호 의사결정에 참여함으로써 정보보호 및 개인정보보호 업무에 대한 책임성과 신뢰성을 향상시킬 수 있다
- ⑤ 기업은 지속적이고 체계적인 ISMS-P 구축을 통해 해킹, DDoS 등의 침해사고 및 개인정보 유출사고 발생 시 신속하게 대응할 수 있는 관리체계를 마련할 수 있다.

STEP BY STEP

- 1 인증의 대상은 미래 사고가 아니라 현재 관리체계의 적합성과 운영 여부다.
- 2 ISMS-P는 16+64+21개 요구사항을 통해 체계적 관리와 대응능력을 높인다.
- 3 어떤 인증도 모든 취약점 제거와 사고 미발생을 보장하지 않는다.
- 4 따라서 안전을 '보장'한다고 한 ②가 틀렸다.

선지별 판정

선지	판정	해 있고 / 왜 틀리는가
①	맞음	ISMS-P는 관리체계 16, 보호대책 64, 개인정보 처리단계 21의 총 101개 인증기준으로 구성된다.
②	정답	인증은 관리체계 적합성의 증명이지 침해사고가 없다는 보증이 아니다.
③	맞음	대외 신뢰와 이미지 제고는 기대효과다.
④	맞음	경영진 책임과 의사결정 참여를 강화한다.
⑤	맞음	지속적 관리체계는 탐지·대응·복구 능력을 높인다.

예랑이랑 통합본 연결

p.30-31, p.86

추가 보강

- 인증범위 밖의 시스템과 인증 이후의 운영 부실은 별도로 남을 수 있다.

근거 키워드

ISMS-P 인증기준 · 개인정보 보호법 제32조의2

시험장에서: 인증=체계 증명, 보장=아님.

Q88. 가상자산사업자 ISMS-P 예비인증

원 해설 정정

정답 결론: ⑤

문제 원문 · 선지

Q88. 가상자산사업자에 대한 ISMS-P 인증 및 특례에 대한 설명으로 적절하지 않은 것은?

- ① 가상자산사업자는 「특정 금융거래정보의 보고 및 이용 등에 관한 법률」에 따라 신고를 위해 정보보호 관리체계 인증 취득이 필수 요구사항이다
- ② 신규 가상자산사업자가 인증기준에 따른 정보보호 관리체계를 2개월 이상 운영하지 못한 경우, 실제 서비스 운영 전 시험 운영 환경에서 '정보보호관리체계 예비인증'을 신청할 수 있다
- ③ 예비인증은 고시 제18조의2 제1항 제2호에 따른 본인증을 받기 위한 조건부 인증이다
- ④ 예비인증은 본인증을 받기 위한 조건부 인증으로서, 예비인증을 취득한 날부터 3개월 이내에 금융정보분석원장에게 신고해야 한다
- ⑤ 가상자산사업자가 예비인증을 취득한 경우, 예비인증 취득일로부터 6개월 이내에 본인증을 취득해야 한다.

원 해설 정정

원 문서는 본인증 기한을 '예비인증 취득일로부터 1년'이라고 설명했으나 현행 고시는 'FIU 신고가 수리된 날부터 6개월 이내'라고 규정한다. ⑤는 6개월이라는 숫자가 아니라 기산점을 예비인증 취득일로 잘못 잡아 틀린 것이다.

STEP BY STEP

- 1 예비인증은 2개월 운영실적을 만들지 못한 신규 사업자가 시험운영 환경에서 받는 조건부 인증이다.
- 2 예비인증 취득일로부터 3개월 이내에 FIU 신고를 해야 한다.
- 3 신고가 수리된 뒤 그 수리일로부터 6개월 이내 본인증을 취득해야 한다.
- 4 ⑤는 예비인증 취득일로부터 6개월이라고 하여 기산점이 틀렸다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	맞음	가상자산사업자 신고에는 ISMS 취득이 핵심 요건이다.
②	맞음	2개월 운영실적이 없는 신규 사업자는 시험운영 환경에서 예비인증을 신청할 수 있다.
③	맞음	예비인증은 본인증을 위한 조건부 인증이다.
④	맞음	예비인증 취득일로부터 3개월 이내 FIU 신고 조건이 붙는다.
⑤	정답	본인증 6개월은 예비인증 취득일이 아니라 신고 수리일로부터 계산한다.

예랑이랑 통합본 연결

직접 수록 없음; p.86-89의 ISMS-P 기본 절차에 추가 보강

추가 보강

- 본인증 신청 전에는 실제 관리체계를 2개월 이상 운영해야 한다.
- 예비인증 효력은 본인증 절차가 완료될 때까지 유효한 것으로 보는 단서가 있다.

근거 키워드

정보보호 및 개인정보보호 관리체계 인증 등에 관한 고시 제18조의2 · 특정금융정보법 제7조

시험장에서: 예비 취득+3개월=신고, 신고 수리+6개월=본인증.

Q89. 중소기업 ISMS-P 인증 특례

정상

정답 결론: ⑤

문제 원문 · 선지

Q89. 중소기업에 대한 ISMS-P 인증의 특례 적용 범위 및 제외 대상에 대한 설명으로 적절하지 않은 것은?

- ① ISMS-P 인증의 특례는 인증에 어려움을 겪는 중소기업의 부담 완화를 목적으로 2024년 7월부터 시행되었다
- ② 인증의 특례는 「중소기업기본법」에 따른 소기업과, 일정 기준을 충족하는 중기업에 대하여 완화된 인증기준 및 절차 등을 적용할 수 있다
- ③ 중기업 중 정보통신서비스 부문 매출액이 300억 원 미만인 자는 인증의 특례 대상에 해당한다
- ④ 정보통신서비스 부문 매출액이 300억 원 이상인 중기업이라도, 주요 정보통신설비를 직접 설치·운영하지 않는 경우에는 특례 대상에 해당할 수 있다
- ⑤ 가상자산사업자도 소기업이거나 정보통신서비스 부문 매출액이 300억 원 미만인 경우에 인증의 특례 대상에 해당된다.

STEP BY STEP

- 1 특례 대상은 소기업과 일정한 중기업이다.
- 2 중기업은 정보통신서비스 매출 300억원 미만이거나, 300억원 이상이어도 주요 설비를 직접 운영하지 않고 인증된 호스팅·클라우드를 이용하는 경우가 핵심이다.
- 3 가상자산사업자·금융회사 등은 위험 때문에 특례에서 제외된다.
- 4 따라서 ⑤가 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	맞음	2024.7 도입된 특례는 중소기업의 인증 부담 완화가 목적이다.
②	맞음	소기업과 일정 중기업에 완화된 기준·절차를 적용한다.
③	맞음	정보통신서비스 부문 매출 300억원 미만 중기업은 대상이 될 수 있다.
④	맞음	주요 설비를 직접 운영하지 않고 인증된 호스팅·클라우드를 이용하는 경우 대상이 될 수 있다.
⑤	정답	가상자산사업자는 규모와 관계없이 특례 제외 대상이다.

예랑이랑 통합본 연결

직접 수록 없음; p.86-89에 추가 보강

추가 보강

- 2026.7.7 시행령은 가상자산사업자와 금융회사를 명시적 제외 대상으로 둔다.

근거 키워드

정보통신망법 제47조의7 · 정보통신망법 시행령 제49조의2

시험장에서: 300억원 요건을 외운 뒤 가상자산·금융 제외를 붙인다.

Q90. ISMS-P 사후관리 및 보완조치

기간 표현 주의

정답 결론: ⑤

문제 원문 · 선지

Q90. ISMS-P 인증 취득 후 사후 관리 및 보완 조치에 대한 설명으로 적절하지 않은 것은?

- ① 사후심사는 인증 유효기간 중 매년 1회 이상 실시하는 인증심사이다
- ② 사후심사는 인증발급일 기준으로 매 1년 이전에 심사를 완료해야 하며, 인증 유효기간 내 심사를 받지 않을 경우 인증이 취소될 수 있다
- ③ ISMS-P 인증은 인증 유효기간 만료 이전에 갱신심사를 통해 유효기간을 갱신하여야 하며, 유효기간이 경과한 때에는 인증의 효력이 상실된다
- ④ 심사팀장은 보완조치내역서의 적절성을 판단하고 이행점검을 통해 실제 이행 여부를 확인한다
- ⑤ 최초심사 신청기관이 연장 기한을 포함하여 최대 40일 이내에 보완조치를 완료하지 못한 경우, 인증위원회 심의·의결을 거쳐 심사가 무효된다.

기간 표현 주의

⑤는 두 군데가 틀렸다. 최초 보완조치 기본기한 40일 외에 최대 60일 연장이 가능해 '연장 포함 최대 40일'이 아니며, 기한 내 미완료 건은 인증위원회 적합성 심의로 넘길 수 없는 상태에서 심사가 무효 처리된다.

STEP BY STEP

- 1 인증 후 3년 유효기간 동안 매년 사후심사 또는 갱신심사 흐름을 본다.
- 2 결함 발견 시 기본 40일 내 보완하고 사유가 있으면 최대 60일 연장할 수 있다.
- 3 심사팀장이 보완 적절성과 실제 이행을 확인한다.
- 4 기한 초과 미완료는 인증위원회가 적합 여부를 심의할 완성된 안건이 아니므로 ⑤가 틀렸다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	맞음	사후심사는 유효기간 중 매년 1회 이상 실시한다.
②	맞음	사후관리 거부·방해는 인증취소 사유가 될 수 있다.
③	맞음	만료 전 갱신심사를 받아야 하며 만료되면 효력을 잃는다.
④	맞음	심사팀장은 보완조치내역과 실제 이행을 확인한다.
⑤	정답	최대기간과 무효 처리 절차를 모두 잘못 설명한다.

예랑이랑 통합본 연결

p.31, p.86-89, p.93

추가 보강

- 3년 유효기간 중 일반적으로 1년차·2년차 사후심사, 3년차 갱신심사 흐름으로 이해한다.

근거 키워드

정보보호 및 개인정보보호 관리체계 인증 등에 관한 고시 · KISA ISMS-P 인증제도 안내서

시험장에서: 보완 40일 + 연장 최대 60일을 분리해 기억한다.

Q93. ISMS-P 인증범위

범위 판단 주의

정답 결론: ①

문제 원문 · 선지

Q93. ISMS-P 인증범위에 대한 고려사항으로 적절하지 않은 것을 고르시오.

- ① 정보통신서비스 관련 이용자 상담, 문의 대응 등을 위해 콜센터를 운영하는 경우, 콜센터 관련 시스템(교환기, CTI, IVR 등)은 의무 심사 범위에 포함한다
- ② 인증 대상 서비스 및 응용시스템을 위해 필요한 데이터가 저장·관리되는 데이터베이스는 심사범위에 포함한다.(회원DB, 운영DB, 백업DB 등)
- ③ 개발서버, 시험서버, 형상관리서버, 모니터링서버, 백업서버, 로그서버, 보안관리서버, 패치관리서버 등은 심사범위에 포함한다
- ④ 인증범위에 포함된 조직 및 인력이 인터넷 사용, 원격접속 등을 위해 필요한 네트워크 장비는 포함한다
- ⑤ 별도의 보안설정 없는 더미(Dummy) 역할을 하는 스위치는 심사범위에서 제외 가능하다.

범위 판단 주의

콜센터가 언제나 제외되는 것은 아니다. 전통적 교환기·CTI·IVR만으로 정보통신서비스와 직접 관련성이 약하면 제외 가능하지만, 상담원이 인증범위 DB에 접근하거나 웹채·앱 상담을 운영하면 관련 조직·시스템이 포함될 수 있다.

STEP BY STEP

- 1 인증대상 정보통신서비스와 직접 관련된 자산·조직·지원시스템을 식별한다.
- 2 회원DB·운영DB·백업DB와 개발·시험·로그·보안관리 서버는 서비스 운영·보호에 직결된다.
- 3 단순 더미 스위치나 관련성 없는 내부 업무시스템은 제외할 수 있다.
- 4 콜센터를 무조건 의무범위라고 한 ①이 가장 부적절하다.

선지별 판정

선지	판정	왜 맞고 / 왜 틀리는가
①	정답	콜센터 시스템은 서비스·개인정보 흐름과의 관련성에 따라 제외 가능하므로 일률적 의무 포함은 틀리다.
②	맞음	서비스 데이터가 저장되는 운영·회원·백업 DB는 포함한다.
③	맞음	개발·시험·형상·로그·보안 서버는 서비스의 운영과 보안에 직접 관련된다.
④	맞음	범위 조직의 인터넷·원격접속 네트워크 장비도 관련 자산이다.
⑤	맞음	보안설정과 서비스 영향이 없는 단순 더미 스위치는 제외할 수 있다.

예랑이랑 통합본 연결

p.87-88

추가 보강

- 인증범위는 자산 명칭이 아니라 서비스와 개인정보 흐름의 관련성으로 정한다.

근거 키워드

ISMS-P 인증제도 안내서의 인증범위 설정 기준

시험장에서: 항상 포함/항상 제외 표현보다 실제 데이터 흐름을 본다.

Q94. Global CBPR

2027 변경 예정

정답 결론: ⑤

문제 원문 · 선지

Q94. Global CBPR(Cross-Border Privacy Rules) 인증에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 개인정보보호위원회는 총괄 부처로서 국내에서 Global CBPR 관련 제반 정책을 수립하고, 한국인터넷진흥원은 '인증기관'으로서 인증심사 업무를수행한다
- ② Global CBPR은 회원국 간 전자상거래를 활성화하고 국경 간 안전한 개인정보 이전을 촉진하기 위한 제도이다
- ③ 해당 인증은 지난 2011년 아시아·태평양 지역 9개 국가를 중심으로 상호 간 인증(APEC CBPR)으로 시작하였으며, 2025년부터 Global CBPR로확대되었다
- ④ Global CBPR은 APEC 프라이버시 9원칙을 이행하기 위한 50개의 인증 기준으로 구성되어 있다
- ⑤ ISMS-P 의무대상자는 개인정보 처리 단계별 보안을 강화하기 위해 해외로 개인정보를 전송하기 하는 경우 의무적으로 Global CBPR 인증을 취득하여야 한다.

2027 변경 예정

④의 50개 요구사항은 2027.3.31까지 유효하다. 2027.4.1부터 신규·갱신 인증에는 57개 요구사항이 적용될 예정이다. 시험 기준일에 따라 숫자가 달라진다.

STEP BY STEP

- 1 Global CBPR은 국경 간 개인정보 보호를 위한 자발적 인증이다.
- 2 국내법을 대체하지 않으며 ISMS-P 의무대상이라는 이유로 자동 의무가 되지 않는다.
- 3 2026.8 기준 기존 50개 프로그램 요구사항이 유효하다.
- 4 의무 취득이라고 한 ⑤가 틀렸다.

선지별 판정

선지	판정	해설고 / 해설리는가
①	대체로 맞음	개인정보위가 정책을 총괄하고 KISA가 국내 인증체계 운영·심사를 담당한다. 최근에는 지정 심사기관 체계도 함께 확인한다.
②	맞음	국경 간 안전한 데이터 이동과 전자상거래 신뢰를 촉진한다.
③	맞음	APEC CBPR에서 출발해 2025.6 Global CBPR 체계가 공식 가동됐다.
④	현재 맞음	기존 50개 요구사항은 2027.3.31까지 유효하다.
⑤	정답	Global CBPR은 자발적 인증이며 ISMS-P 의무대상자의 필수 요건이 아니다.

예랑이랑 통합본 연결

p.33, p.67

추가 보강

- 2027.4.1부터 57개 요구사항 적용: 민감·아동정보, 위험평가, 침해통지, 선택권, 처리기록, 책임자 자격 등이 강화된다.
- CBPR은 컨트롤러, PRP는 프로세서를 위한 체계다.

근거 키워드

Global CBPR Forum Program Requirements · KISA CBPR · 개인정보 보호법 제28조의8

시험장에서: 50개(~2027-03-31), 57개(2027-04-01~)로 날짜와 묶는다.

Q95. ISO/IEC 27001:2022

정상

정답 결론: ③

문제 원문 · 선지

Q95. 국제 정보보호 경영시스템 인증제도(ISO/IEC 27001:2022)에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 정보보안경영시스템(ISMS: Information Security Management System)에 대한 국제표준으로서, 해당 조직이 정보보호경영을 실행하기 위한프레임워크를 확립하고 이를 자사에 적용할 수 있도록 안내하는 인증 제도이다
- ② 각 나라별로 인정기관 및 인증기관을 지정하여 운영하며, 인증기관 내 인증위원회에서 인증결과를 심의하고 의결한다
- ③ ISO/IEC 27001은 10가지 핵심 항목과 14개 분야의 총 114개 관리 통제 항목으로 구성되어 있다
- ④ 인증심사는 문서심사와 현장심사로 이루어지며, 인증 유효기간은 3년이다. 인증 취득 후에는 연 1회 이상 사후 심사를 받아야 한다
- ⑤ ISO/IEC 27001 인증을 취득한 경우, 국내 정보보호 관리체계(ISMS) 인증심사 일부를 생략할 수 있다.

STEP BY STEP

- 1 ISO/IEC 27001:2013과 2022의 Annex A 구조를 구분한다.
- 2 2013판은 14개 분야 114개 통제, 2022판은 4개 주제 93개 통제다.
- 3 2013판 숫자를 2022판 설명에 넣은 ③이 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	맞음	조직이 위험기반 ISMS를 수립·운영·개선하도록 하는 국제표준이다.
②	맞음	각국 인정기관 아래 인증기관이 심사·인증을 운영하는 구조다.
③	정답	14개 분야 114개는 2013판이고 2022판은 4개 주제 93개다.
④	맞음	통상 3년 인증주기와 정기 사후심사를 운영한다.
⑤	조건부 맞음	법령·고시가 정한 경우 ISMS 단일심사의 일부 항목을 생략할 수 있지만 ISMS-P 전체 대체를 뜻하지 않는다.

예랑이랑 통합본 연결

p.33, p.86, p.88

추가 보강

- 2022판 4개 주제: 조직 37, 인적 8, 물리 14, 기술 34 = 93.

근거 키워드

ISO/IEC 27001:2022 · ISO/IEC 27002:2022 · ISMS-P 인증제도 안내서

시험장에서: 2013=14/114, 2022=4/93.

Q96. 개인정보 영향평가(PIA)

정상

정답 결론: ③

문제 원문 · 선지

Q96. 개인정보 영향평가(PIA)에 대한 설명으로 가장 적절하지 않은 것을 고르시오.

- ① 개인정보 영향평가는 개인정보 처리가 수반되는 사업 추진 시 개인정보 침해사고를 사전에 예방하는 것을 목적으로 한다
- ② 개인정보 영향평가 대상자가 이를 수행하지 않거나 그 결과를 보호위원회에 제출하지 아니한 경우 3천만원 이하의 과태료가 부과될 수 있다
- ③ 모든 개인정보처리자(공공기관, 민간 기업 등)는 개인정보 영향평가에서 정하는 대상 기준에 포함될 경우 의무적으로 이를 수행하여야 한다
- ④ 개인정보 영향평가는 대상 시스템의 설계 완료 전에 영향평가를 수행하고 그 결과는 시스템 설계·개발 시 반영해야 한다
- ⑤ 영향평가는 개인정보보호위원회가 지정한 영향평가기관에 의뢰하여 영향평가를 수행하고 그 결과 및 요약본을 최종 제출받은 날로부터 2개월 이내에 개인정보보호위원회에 제출해야 한다.

STEP BY STEP

- 1 의무 주체를 먼저 확인한다: 영향평가 법정 의무는 일정 기준의 개인정보파일을 운용하는 공공기관이다.
- 2 민간은 침해 우려가 있으면 자율적으로 적극 노력하는 구조다.
- 3 설계 완료 전 평가하고 결과를 2개월 이내 제출한다.
- 4 모든 민간까지 의무라고 한 ③이 틀렸다.

선지별 판정

선지	판정	해설고 / 해설리는가
①	맞음	사전에 침해요인을 찾아 설계에 개선사항을 반영하는 것이 목적이다.
②	맞음	의무 대상 공공기관의 미 실시·미제출은 과태료 대상이 될 수 있다.
③	정답	민간 기업은 기준에 해당해도 법정 의무대상이라는 문장은 틀리다.
④	맞음	분석·설계 단계, 즉 설계 완료 전에 수행해 개발에 반영한다.
⑤	맞음	지정 평가기관에 의뢰하고 평가서를 받은 날부터 2개월 이내 제출한다.

예랑이랑 통합본 연결

p.32, p.90-93

추가 보강

- 대상 기준: 5만명 민감·고유식별, 50만명 연계, 100만명 개인정보파일을 구분한다.
- 사립학교가 법상 공공기관 범주에 포함되는지 개별 기관 성격을 확인한다.

근거 키워드

개인정보 보호법 제33조 · 개인정보 보호법 시행령 제35조-제38조

시험장에서: PIA 의무=공공, 민간=자율 노력.

Q97. 위치정보법 총론

정상

정답 결론: ①

문제 원문 · 선지

Q97. 위치정보의 보호 및 이용 등에 관한 법률에 대한 설명으로 적절하지 않은 것을 고르시오.

- ① 위치정보법은 개인위치정보와 관련한 사업을 영위하려는 자에게만 해당하며 일정한 제한을 규정하고 있다
- ② 개인위치정보 수집 시에는 사전에 개인위치정보주체의 동의를 얻어야 하고, 수집한 개인위치정보를 이용하거나 제3자에게 제공하는 경우에도 별도 동의를 얻어야 한다
- ③ 위치정보의 유출, 변조, 훼손 등을 방지하기 위해 위치정보법은 위치정보사업자 등에 기술적·관리적 조치 의무를 부여하고 있다
- ④ 개인위치정보란 \"특정 개인\"의 위치정보를 말하므로 위치정보를 통해 식별하여 구분할 수 있는 자연인의 위치정보만을 의미하고, 법인이나 단체, 개인 집합체 등의 장소 정보는 제외한다
- ⑤ 이동성이 있는 물건의 위치정보로서 다른 정보와 용이하게 결합하여 특정 개인의 위치를 알 수 있지 아니한 경우에는 위치정보의 수집·이용·제공시에 소유자의 사전 동의가 요구되지 않는다.

STEP BY STEP

- 1 위치정보법은 사업 허가·신고만 다루는 법이 아니라 위치정보를 수집·이용·제공하는 여러 주체의 의무를 정한다.
- 2 개인위치정보는 특정 개인의 위치를 뜻하고 법인·단체의 장소정보는 제외된다.
- 3 개인과 쉽게 결합되지 않는 사물 위치는 개인위치정보가 아니다.
- 4 사업자에게만 해당한다고 한 ①이 틀렸다.

선지별 판정

선지	판정	해 맞고 / 해 틀리는가
①	정답	사업자 외에도 개인위치정보를 처리·이용하는 자와 위치정보주체의 권리 등 넓은 관계를 규율한다.
②	맞음	수집과 이용·제공에는 각각 법이 요구하는 동의·고지가 필요하다.
③	맞음	사업자 등에게 기술적·관리적 보호조치 의무가 있다.
④	맞음	개인위치정보는 자연인 개인의 위치정보다.
⑤	맞음	특정 개인과 쉽게 결합되지 않는 사물 위치는 개인위치정보 동의 규율 대상이 아니다.

예랑이랑 통합본 연결

통합본 직접 수록 없음; p.08의 위치 데이터와 별도 연계

추가 보강

- 위치정보와 개인위치정보를 구분한다. 모든 위치정보가 개인정보인 것은 아니다.
- Q3의 웨어러블 위치 데이터처럼 개인과 결합되면 위치정보법 검토가 필요하다.

근거 키워드

위치정보법 제2조, 제16조, 제18조-제21조

시험장에서: 사람 위치인가, 사물 위치가 사람과 쉽게 결합되는가를 먼저 본다.

Q98. 위치정보법 제18조 이용약관 명시사항

정상

정답 결론: ⑤

문제 원문 · 선지

Q98. 위치정보사업자가 개인위치정보를 수집하고자 하는 경우 개인위치정보주체의 동의를 얻어야 한다. 동의를 얻을 시 이용약관에 명시해야 하는 내용으로 적절하지 않은 것을 고르시오.

- ① 위치정보사업자의 상호, 주소, 전화번호 그 밖의 연락처
- ② 개인위치정보주체 및 법정대리인의 권리와 그 행사방법
- ③ 개인위치정보의 보유목적 및 보유기간
- ④ 위치정보 수집사실 확인자료의 보유근거 및 보유기간
- ⑤ 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용

STEP BY STEP

- 1 위치정보법 제18조 제1항의 이용약관 명시사항을 그대로 대조한다.
- 2 상호·연락처, 권리행사, 서비스 내용, 수집사실 확인자료, 보유목적·기간이 법정 항목이다.
- 3 동의 거부권·불이익 고지는 일반 동의 규율에서 중요하지만 제18조 제1항의 열거 항목은 아니다.
- 4 따라서 ⑤가 적절하지 않다.

선지별 판정

선지	판정	해 맞고 / 왜 틀리는가
①	맞음	사업자의 상호·주소·전화번호 등 연락처는 명시사항이다.
②	맞음	개인위치정보주체와 필요한 경우 법정대리인의 권리·행사방법을 적는다.
③	맞음	개인위치정보의 보유목적·보유기간은 명시사항이다.
④	맞음	수집사실 확인자료의 보유근거·보유기간을 적는다.
⑤	정답	제18조 제1항의 이용약관 열거 항목에 직접 들어 있지 않다.

예랑이랑 통합본 연결

통합본 직접 수록 없음

추가 보강

- 제18조에는 위치기반서비스사업자에게 제공하려는 서비스 내용도 포함되는데 이 문항 선지에는 나오지 않았다.
- 정보주체는 수집 범위와 이용약관 일부에 대해 동의를 유보할 수 있다.

근거 키워드

위치정보법 제18조

시험장에서: 상호-권리-서비스-확인자료-보유목적 순으로 외운다.

공식 근거 · 추가 확인 링크

- 국가법령정보센터 - 개인정보 보호법

<https://www.law.go.kr/법령/개인정보보호법>

- 국가법령정보센터 - 개인정보 보호법 시행령

<https://www.law.go.kr/법령/개인정보보호법시행령>

- 개인정보의 안전성 확보조치 기준

<https://www.law.go.kr/행정규칙/개인정보의안전성확보조치기준>

- 위치정보의 보호 및 이용 등에 관한 법률

<https://www.law.go.kr/법령/위치정보의보호및이용등에관한법률>

- KISA ISMS-P

<https://isms.kisa.or.kr/>

- KISA CSAP 제도소개

<https://isms.kisa.or.kr/main/csap/intro/>

- KISA CBPR

<https://cbpr.kisa.or.kr/>

- Global CBPR Forum

<https://www.globalcbpr.org/>

- ISO/IEC JTC 1/SC 27

<https://committee.iso.org/home/jtc1sc27>

- 개인정보보호위원회 가명정보 처리 가이드라인

<https://www.pipc.go.kr/>

자료 사용 메모

첫 번째 PDF의 문제 지문과 선지는 사용자 요청에 따라 보존했습니다. 두 번째 '예랑이랑' PDF는 개인 학습 범위에서 관련 페이지를 대조하고 내용을 요약·보강했으며, 원문 전체나 도표를 복제하지 않았습니다.

이 책에서 가장 중요한 습관: 숫자만 외우지 말고 주체·조건·기산점·시행일을 한 묶음으로 확인하세요.